文件編號：XXXXXXXXXX

加雲聯網股份有限公司

Dummy Project - Security Functional Description Specifications & Menus

版 別：1.0

制訂日期：2024 年 5 月 XX 日

修訂日期：2024 年 5 月 XX 日

制修部門：XXX

頁 數：X

核准	審查	制定

文件發行/修訂記錄

版次	發行日期	生效日期	制修內容摘要
1.0			

CONTENTS

1.0 Introduction 5
1.1 Purpose and Objectives 5
1.2 Scope of application 5
1.3 Glossary of Term and Definitions 5
1.3.1 Definitions 5
1.3.2 Abbreviations 5
1.4 Applicable Documents 6
1.4.1 Employer's Requirements 6
1.4.2 Related Documents 6
2.0 Design Principles for OT-Security 7
2.1 Secure by Design 7
2.2 Reduce Attack Surface 7
2.3 Defense-in-Depth 7
2.4 Partition and Isolation of Security Zones 8
2.5 Essential Functions 8
3.0 Asset Management 9
3.1 Asset Baselining 9
3.2 Asset Inventory Management 9
3.3 Secure Time Authentication and Synchronization 9
3.4 Application Control 10
3.5 Application Error Handling Mechanisms 11
4.0 Endpoint Security 12
4.1 Malicious Code Prevention 14
4.2 Malicious Code Prevention 20
4.3 Endpoint Protection Device 21
4.4 Data Protection in Device 23
4.5 Disposal of Systems and Devices 27
5.0 Hardening Control 28
5.1 Application and User Hardening Management 28
5.2 Certificate Authority (CA) Management 29
6.0 Identity and Access Management (IAM) 32
6.1 Use Control and Least Functionality Settings 32
6.2 Internal and External User Access Controls 33
6.3 Network Assess Controls 35
6.4 Application Access Controls 38
6.5 User Access Rights and Role-based Access Controls 38
6.6 Access and Administration Mechanisms 39
7.0 Security Patching 49
7.1 Patch Management 49
7.2 Validation and Testing 56
8.0 Backup and Restore 57
8.1 Backup Schedules Configuration 57
8.2 Recovery Testing Mechanisms 70
8.3 Device and Network Redundancy Configuration 70
8.4 Emergency Power Supply Configuration 71
9.0 Remote Interactive Access 72

9.1 Session Logging – Event Management 72
9.2 Default Credentials Removed 73
9.3 Multifactor Authentication 73
10.0 Network Security 76
10.1 Network Segmentation 76
10.2 Zoning and Conduits 76
10.3 Documentation and Schematics 78
10.4 Logging and Auditing Controls – Event Management 78
10.5 Communication Protection 79
11.0 Logging and Auditing – Event Management 81
11.1 Auditable Events Identification 81
11.2 User Logging Configuration 82
11.3 Device Logging Configuration 82
11.4 Network Logging Configuration 83
11.5 Security Tools Logging – Malware Protection 84
11.6 Threat Detection 85
11.7 Intrusion Detection and Protection Configuration 85
11.8 Monitoring Use Cases 85
12.0 Safety Instrumented System (SIS) 86
12.1 Safety Instrumented System (SIS) security (if applicable) 86
13.0 Wireless Security 93
13.1 Wireless Security (if applicable) 93

1.0 Introduction

1.1 Purpose and Objectives

The purpose of this document is to document the Security Functional Description and operational menu. This document describes the operation menu of Design Principles for OT-Security, Asset Management, Endpoint Security, Hardening Control, Identity and Access Management (IAM), Security Patching, Backup and Restore, Remote Interactive Access, Network Security, Logging and Auditing – Event Management, Safety Instrumented System (SIS), and Wireless Security for the dummy project.

1.2 Scope of application

The scope of this document is including the SCADA HMI Server in SuC.

1.3 Glossary of Term and Definitions

1.3.1 Definitions

Definition	**Description**
Asset Owner	Individual or organization responsible for one or more Industrial Automation and Control Systems (IACSs).
Automation Solution	Control system and any complementary hardware and software components installed and configured to operate in an IACS.
Component	One of the parts that make up a product or system.
Dependent Component	Component external to the product on which the product depends.
Integration Service Provider	Service provider that provides integration activities for an Automation Solution including design, installation, configuration, testing, commissioning, and handover.
Maintenance Service Provider	Service provider that provides support activities for an Automation Solution after handover.
Product Supplier	Manufacturer of hardware and/or software products.
Recovery Point Objective	Time value that determines the maximum tolerable period of data loss due to a disaster (e.g., data corruption).
Recovery Time Objective	The overall length of time an information system's components or an operation system's components can be in the recovery phase before negatively impacting the organization's mission or mission/business/operating functions.
Service Provider	Individual or organization (internal or external organization, manufacturer, etc.) that provides a specific support service and associated supplies in accordance with an agreement with the asset owner.

1.3.2 Abbreviations

Abbreviation	**Clarification**
SAT	Site Acceptance Test
SCS	Substation Control System

Abbreviation	Clarification
SIT	Site Integration Test

1.4 Applicable Documents

1.4.1 Employer's Requirements

No	Employer's DOC No	DOC Title
1		
2		
3		

1.4.2 Related Documents

No	Project's DOC No	Employer's DOC No	DOC Title
1	DUMMY202400##	BOSS202400##	ID10_Dummy Project - Simple Network Diagram
2	DUMMY202400##	BOSS202400##	ID08 Dummy – Data flow diagram
3	DUMMY202400##	BOSS202400##	ID09 Dummy Project - Inventory Asset List
4	DUMMY202400##	BOSS202400##	ID11_x Dummy Project - ILRA-DTRA
5	DUMMY202400##	BOSS202400##	ID11_Dummy Project - Threat and Risk Assessment Report

2.0 Design Principles for OT-Security

2.1 Secure by Design

Secure by Design is a design principle that implements security measures early in the Industrial Automation and Control System (IACS) lifecycle. Its purpose is to establish robust security policies/countermeasures, security architectures and security practices early in development and implement them throughout the lifecycle. This design principle applies to both product development and automation solution development. When using secure by design principles, security measures can operate natively within a control system or component without adding compensatory countermeasures.

2.2 Reduce Attack Surface

Reducing the attack surface is a design principle under which the physical and functional interfaces that can access the IACS vulnerable to potential attacks are minimized, thus making it more difficult for the attack to succeed. The attack mitigation interface includes the following design principles:

1 Access Control: Restrict physical and logical access to IACS systems and networks;
2 Network Segmentation: Segment IACS networks and control traffic between them;
3 Least Function: Harden IACS systems and networks by removing unneeded functionality. This is the responsibility of the product/solution providers; and
4 Least Privilege: Restrict privileges to the minimum required for a role or function. This is the responsibility of the system integration service or maintenance Server Providers to be properly configurated an IACS automation solution. The Asset Owner's product/solution users operate the IACS automation solution by following the proper system architecture.

2.3 Defense-in-Depth

Defense in depth is defined as providing multiple security protections, especially in layers, designed to delay or prevent attacks. Defense in depth means that layers of security and detection are required even on a single system and requires preventing attackers from breaking through or bypassing multiple layers without being detected. The IACS is still protected even if a vulnerability in one layer is compromised. Special attention must be paid to a single vulnerability/weakness that still has the potential to compromise multiple layers of protection.

The first default rule in all Firewall of OT Conduit should be “Deny All”.

The defense-in-depth architecture of SuC include:

1 Outside zone to Purdue Level 3
   (1). Setup a Firewall with limiting the allowed asset and service connetion from Substation Zone to Supervisory zone and Service zone.
   (2). Require multi-factor authentication for the connetion from Substayion Zone.
   (3). Encrypt the connetion from Substayion Zone.
   (4). Setup a firewall with limiting the allowed asset and service connetion from

Working Zone to Supervisory zone.

(5). Request the security for Web access from Working Zone to Supervisory zone.

(6). Encrypt the connection from Working Zone.

2 Purdue Level 3 to Purdue Level 2

(1). Setup a Managed Switch with whitelisting asset list to limit the allowed asset and service connection from Service Zone to Supervisory zone, Safety Zone, and Control zone.

3 Purdue Level 2 to Purdue Level 1

(1). Setup a Router with Firewall with whitelisting asset list to limit the allowed asset and service connection from Service Zone, Supervisory zone to Safety Zone, and Control zone. The whitelisting allowed data flow should be limited to 4.0 SuC dataflow diagram.

(2). Setup a Router with Firewall with firewall rule only allow limiting asset and service connection from Supervisory zone to Safety Zone. The whitelisting allowed data flow should be limited to 4.0 SuC dataflow diagram.

(3). All the communications external to the Safety (SIS) Zone, including remote access communications, should be prohibited to interfere with the operation of the SIS. All remote access communications (ex. Port 3389) with IPs in Safety (SIS) Zone should be denied in Router with Firewall rules.

(4). The IEDs in Safety (SIS) Zone should set to “Run mode” in configuration application or by a manual physical switch (disable SIS configuration mode) when they are under operation, to prohibit the SIS from being configured.

2.4 Partition and Isolation of Security Zones

It shall comply with IEC 62443-3-2 zone and conduit partition, separation and isolation principles:

1 Business and IACS assets shall be separated;

(1) Safety related assets shall be separated – Separation principle used in functional safety engineering shall be followed. That is, safety related systems shall be separated from basic process control systems;

(2) Temporarily connected devices should be separated;

(3) Wireless devices should be separated; and

(4) Devices connected through an external network should be separated.

2.5 Essential Functions

Essential functions are defined as functions required to maintain Health, Safety, and Environment (HSE) and Equipment under Control (EUC) availability. Essential functions include:

1 Safety Instrumented Function (SIF);

(1) Critical control functions; and

(2) The ability of operators to view and manipulate EUC.

3.0 Asset Management

List of subsystems or assets to which these security measures/countermeasures apply. Please refer to the items given in Section 1.2 to perform applicability screening.

Refer to ID06 Dummy Project - Inventory Asset List .xlsx

3.1 Asset Baselining

This requirement is related to IEC 62443-2-4 SP06.02BR.
Please show Asset Inventory Register, including version numbers and serial numbers of all devices and software components and present checklists/template of inventory register evidence reference file/document number or result in this section.
Description relates to 7.2.1-2. (SP06.02BR)
Note that this is specified the content of Asset Management.

3.2 Asset Inventory Management

This requirement is related to IEC 62443-2-4 SP06.02BR.
Please describe the process or procedure on how to create and maintain the latest version of the Section 3.1 Asset Inventory Register in this section.
Description relates to 7.2.2.-2. & 3. (SP06.02BR)
Note that this is a maintenance process of asset management, and this section is related to CCM process in 7.4.1.4 specifies that the Configuration and Change Management (CCM) process.

3.3 Secure Time Authentication and Synchronization

This requirement is related to IEC 62443-2-4 SP.03.04 BR.
Please describe or show the evidence references given below in this section:

1 Description and/or diagram that illustrates the security of the time source (i.e., reliable time source);
   (1) Identification of the recommended time distribution protocol and explanation of its reliability;
   (2) Procedure for selecting and approving time distribution protocol (Or state that the Employer's procedural requirements have been complied with); and
   (3) Evidence (articles, papers, studies) showing that the protocol is commonly accepted and current, and not obsolete or unacceptable (Or state that the protocol used is commonly accepted and well known in the field of industrial control).
   Description relates to 7.4.1.2-2. (SP.03.04 BR).

Network Time Protocol

From Wikipedia, the free encyclopedia

Not to be confused with Daytime Protocol, Time Protocol, or NNTP.

The **Network Time Protocol** (**NTP**) is a networking protocol for clock synchronization between computer systems over packet-switched, variable-latency data networks. In operation since before 1985, NTP is one of the oldest Internet protocols in current use. NTP was designed by David L. Mills of the University of Delaware.

NTP is intended to synchronize all participating computers to within a few milliseconds of Coordinated Universal Time (UTC).[1]:3 It uses the intersection algorithm, a modified version of Marzullo's algorithm, to select accurate time servers and is designed to mitigate the effects of variable network latency. NTP can usually maintain time to within tens of milliseconds over the public Internet, and can achieve better than one millisecond accuracy in local area networks under ideal conditions. Asymmetric routes and network congestion can cause errors of 100 ms or more.[2][3]

The protocol is usually described in terms of a client–server model, but can as easily be used in peer-to-peer relationships where both peers consider the other to be a potential time source.[1]:20 Implementations send and receive timestamps using the User Datagram Protocol (UDP) on port number 123.[4][5] They can also use broadcasting or multicasting, where clients passively listen to time updates after an initial round-trip calibrating exchange.[3] NTP supplies a warning of any impending leap second adjustment, but no information about local time zones or daylight saving time is transmitted.[2][3]

The current protocol is version 4 (NTPv4), which is a proposed standard as documented in RFC 5905. It is backward compatible with version 3, specified in RFC 1305.

Network Time Security (NTS), a secure version of NTP with TLS and AEAD is a proposed standard and documented in RFC 8915.

3.4 Application Control

Please specify in this section regarding the understanding of Software and who is responsible, **if applicable**.

Software	**Ver**	**Function description**
Intel® Network Connections		Implanted software
Microsoft Edge		Implanted software
Microsoft OneDrive		Implanted software
Realtek High Definition Audio Driver		Implanted software
HMI SW		To show/monitor the equipment of XXX system about its location and event.
Splunk Agent Alternative		Supported by XXXXX, Security monitoring of Microsoft Windows based servers
Palo Alto Antivirus		Supported by XXXXX,Anti-malware protection
Acronis		Supported by XXXXX, Virtual Machine Disposition for

3.5 Application Error Handling Mechanisms

Error handling refers to the response and recovery procedures from error conditions present in a software application or an IACS automation solution. In other words, it is the process comprised of anticipation, detection and resolution of application errors, programming errors or communication errors.

Please describe application error handling mechanisms in this section, **if applicable**.

Software	**Process**
HMI	Step1. Check if the software is working properly. Step2. View software error messages. Step3. Dispose of according to historical records or software display messages (for example: insufficient hardware space, insufficient license, communication error, etc.) Step4. Restart the application software. Step5. Check if the system is functioning properly. Step6. If the system continues to be abnormal, please notify the responsible person
Splunk Agent Alternative	Step1. Confirm software functionality with XXXXX support Step2. Follow the software operation manual. Step3. Check if the system is back up and running.
Palo Alto Antivirus	Step1. Confirm software functionality with XXXXX support Step2. Follow the software operation manual. Step3. Check if the system is back up and running.
Acronis	Step1. Confirm software functionality with XXXXX support Step2. Follow the software operation manual. Step3. Check if the system is back up and running.

4.0 Endpoint Security

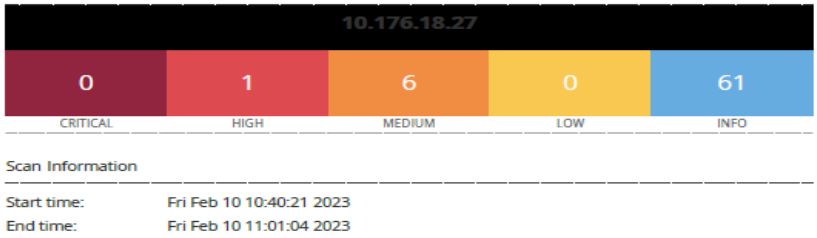
List of subsystems or assets to which these security measures/countermeasures apply.

Endpoint security refers to the practice of protecting a system from the XXX from local or remote devices. Endpoints are the means of entry for assets and applications and represent potential network security vulnerabilities. Examples include desktop computers, notebook computers, servers, workstations, and all network communication equipment.

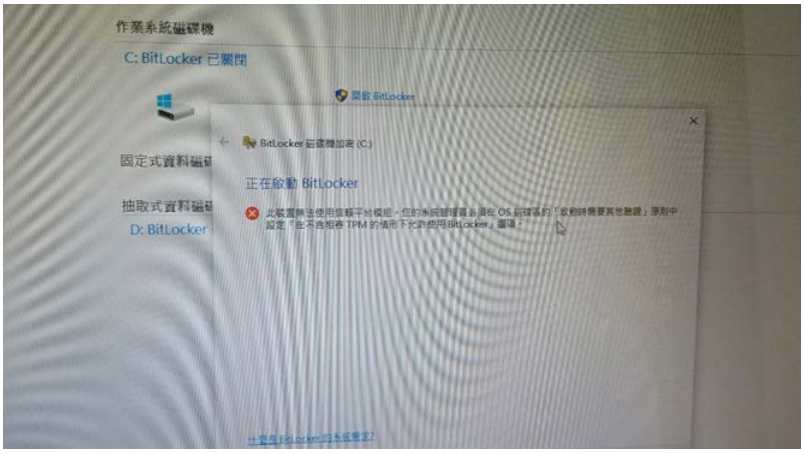
For endpoint defense, it includes the following: XXXXX network switch routing settings and IP whitelisting, server hardening control management and XXXXX supported software, personnel access control and physical locking protection.

Prevent unauthorized access to critical applications and IT/OT systems and defend against malware and other vulnerabilities.

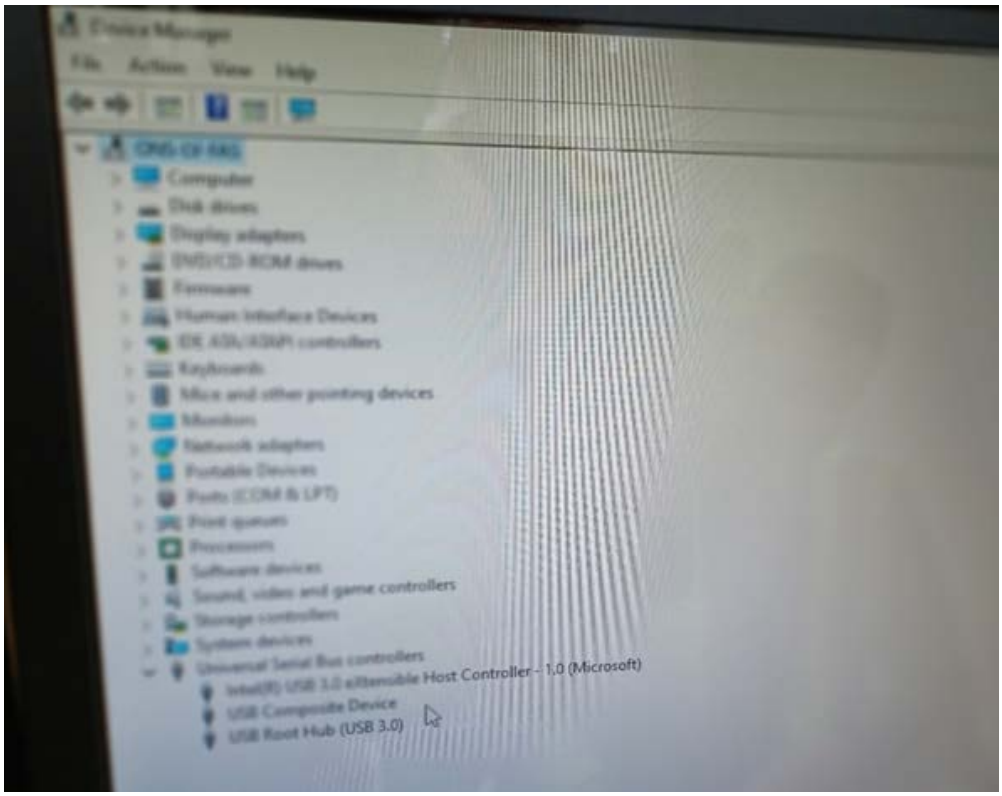
1. Server
   - Equipment hardening
   - Asset device locking control
   - VIT vulnerability scanning results, refer to Report generated by Nessus.

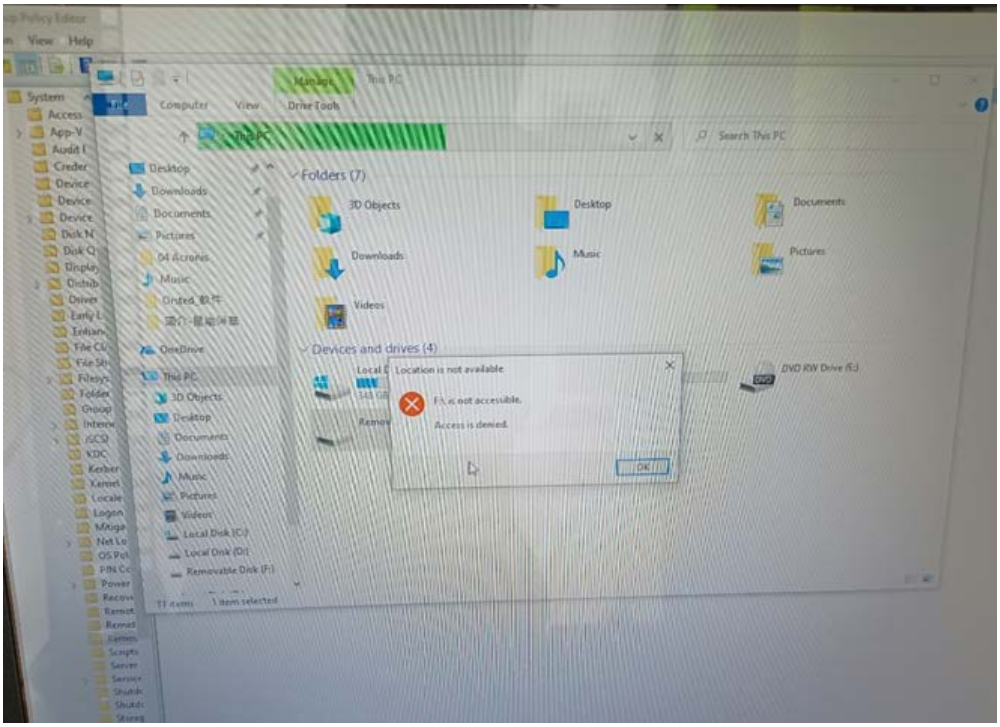


   - System C hard drive protection



   - Check Device Manager for logical interfaces
   - USB storage disabled


Computer
Disk drives
Display adapters
DVD/CD-ROM drives
Firmware
Human Interface Devices
Keyboards
Mice and other pointing devices
Monitors
Network adapters
Portable Devices
Ports (COM & LPT)
Print queues
Processors
Software devices
Sound, video and game controllers
Storage controllers
System devices
Universal Serial Bus controllers
Intel(R) USB 3.0 eXtensible Host Controller - 1.0 (Microsoft)
USB Composite Device
USB Root Hub (USB 3.0)


Folders (7)
3D Objects
Desktop
Documents
Downloads
Music
Pictures
Videos
Devices and drives (4)
Location is not available
F:\ is not accessible.
Access is denied.
OK

- This system is logged into Windows or the operating software account
- Endpoint security is protected according to antivirus software "Palo Alto Antivirus".
- Identification of the recommended time distribution protocol and explanation of its reliability.

4.1 Malicious Code Prevention

This requirement is related to IEC 62443-2-4 SP.10.01 BR, SP.10.02 BR, SP.10.02 RE (1), SP.10.03 BR, SP.10.04 BR, SP.10.05 BR, SP.10.05 RE (1), and SP.10.05 RE (2). Please state the following relevant evidence or practice in this section if appropriate:

1 Description relates to 7.4.1.10-1. (SP.10.01 BR).

(1) After evaluating the impact of installing antivirus software on existing operating systems, provide instructions to the Asset Owner for the use and maintenance of anti-malware mechanisms, such as "Palo Alto Antivirus".

(2) According to the antivirus software "Palo Alto Antivirus", verify whether the installation process of the antivirus software is successful and does not affect the system function, where "Palo Alto Antivirus" provides endpoint protection in an automated solution:

According to the software installation manual step procedure,

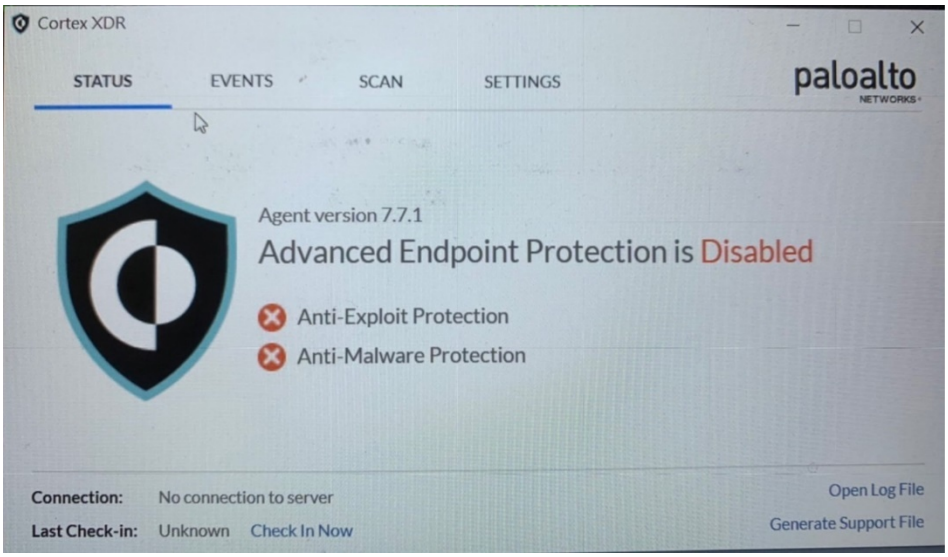
Antivirus software installed and verified through remote support, verify that the antivirus software functions normally and does not affect system operation.

2 Description relates to 7.4.1.10-2. (SP.10.02 BR).

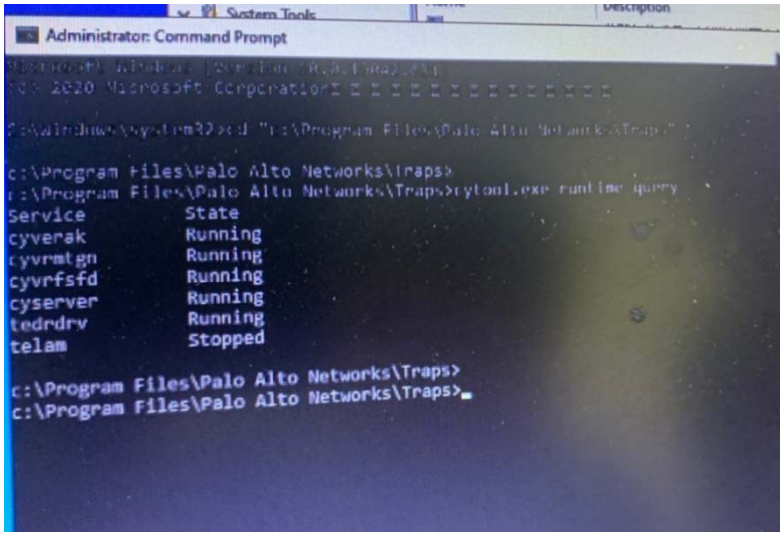
Correct installation and configuration of malware protection mechanisms

(1) Maintenance and update of the installed malware protection mechanisms (e.g., keeping malware definition files current) in cooperation with Asset Owner

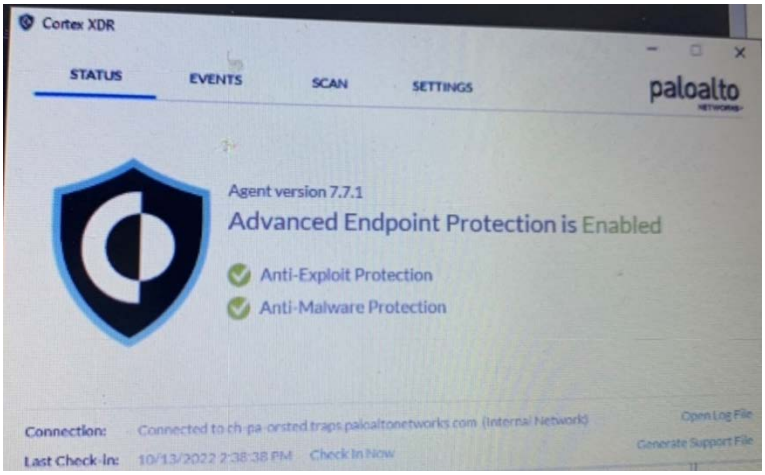
Correctly install antivirus software and configure it according to the installation manual.



(2) Open the CMD type Console tool with administrator privileges and use the relevant commands to open the internal folder for configuration.



(3) Manually configure to the specified IP address.
(4) After the software connects to the specified IP, the endpoint protection function is successfully activated.



The following is the installation Checklist for Malware Protection Mechanisms.

Title	**Installation Checklist**
Date	
Inspector	
Asset ID	
Malware Protection Mechanisms	Palo Alto Antivirus
Inspection	**Items**
	Verify system requirements: Ensure the target system meets the minimum hardware and software requirements.
	Download the latest available version of the malware protection software from the official source.
	Install the software on the system.
	Select installation options: Custom or default settings as per your environment (e.g., automatic scanning, exclusions).
	Confirm successful installation: Check that the software launches correctly and that all components are installed.
Signature	

The following is the patching and update Checklist for Malware Protection Mechanisms.

Title	Patching and Update Checklist
Date	
Inspector	
Asset ID	
Malware Protection Mechanisms	Palo Alto Antivirus
Inspection	**Items**
	Check for available updates: Verify if there are any pending updates or patches for the malware protection software.
	Download and install patches: Ensure that patches, updates, or new versions are applied as soon as they are available.
	Verify the update: Confirm the software's version number after the update to ensure successful installation of patches
	Test patch functionality: Run a basic scan or perform specific tests to verify the software operates correctly after patching.
	Confirm automatic update settings: Ensure that the system is configured to automatically check for and apply updates in the future.
Signature	

The following is the configuration Checklist for Malware Protection Mechanisms.

Title	Configuration Checklist
Date	
Inspector	
Asset ID	
Malware Protection Mechanisms	Palo Alto Antivirus
Inspection	**Items**
	Set up scheduled scans: Define the frequency of full system scans (daily, weekly, etc.) and ensure that the scanning schedule aligns with the organization's policy.
	Configure real-time protection: Ensure real-time scanning is enabled to monitor file system activities, incoming traffic, etc.
	Enable automatic quarantine: Set up automatic actions for detected threats (e.g., quarantine or delete) based on the severity of the threat.
	Define exclusion rules: If necessary, specify trusted applications, files, or directories that should not be scanned.
	Configure reporting and alerts: Set up notification rules for the detection of threats, scanning reports, or any configuration issues.
	Set up logging: Ensure that logs of detected threats, scans, and updates are stored securely and regularly monitored.
	Activate cloud protection (if available): Enable cloud-based protection if the software offers a cloud-based threat intelligence feature.
Signature	

The following is the final verification Checklist for Malware Protection Mechanisms.

Title	Final Verification Checklist
Date	
Inspector	
Asset ID	
Malware Protection Mechanisms	Palo Alto Antivirus
Inspection	**Items**
	Verify malware definition files are up-to-date: Ensure the malware protection mechanism has the latest virus/malware definitions. • Check the last update date and time. • Verify that the software can connect to the definition update server.
	Test manual update process: Manually initiate a definitions update to confirm that the software can successfully update without errors.
	Run a quick scan: Run a quick scan to verify that the software is working as expected and can detect known test malware.
	Check for any errors or warnings: Review logs for any errors or warnings indicating issues with updates or scans.
	Verify configuration settings: Double-check the configuration to confirm that settings such as real-time protection, scheduled scans, exclusions, and alerts are set as desired.
	Perform a system reboot: After all changes, reboot the system to ensure that the malware protection software initializes properly during system startup.
	Check for automatic startup: Verify that the malware protection software starts automatically when the system boots up.
Signature	

3 Description relates to 7.4.1.10-2. (1) (SP.10.02 RE (1)).

Provide a process that can be performed for the Asset Owner to document and maintain the antimalware software status for each component of the Automation Solution according points 1) to 4) of the requirement

(1) the installation state of malware protection mechanisms or a statement that it is not technically possible to install malware protection mechanisms on the component;
(2) the current configuration settings of the installed malware protection mechanism;
(3) the current status of malware definition files approved for installation on the component; and
(4) the use of other mitigating features and functions used to reduce the risk of infection and/or mitigate the effect of infections (e.g., isolating infections, reporting infections).

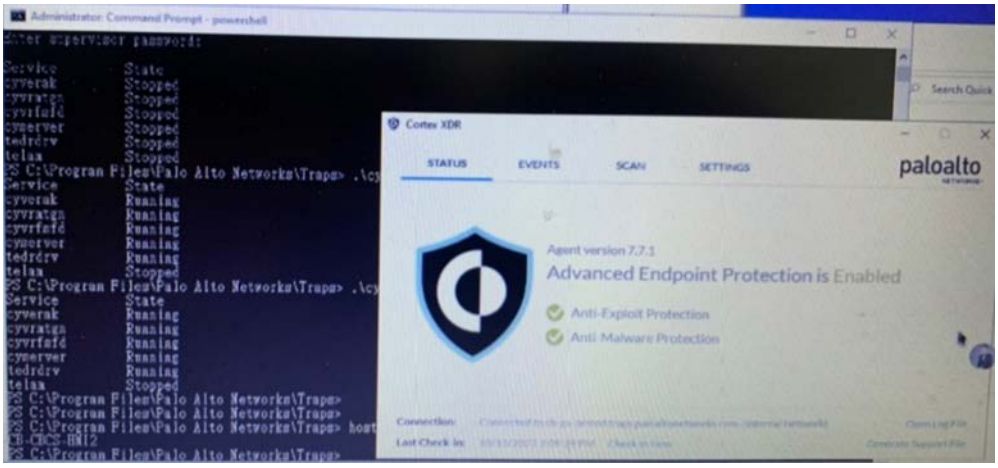
Documented Process for Alternative Mitigation Measures When Malware Protection Mechanisms Are Not Feasible, Available, or Applicable:

(1) Before implementing alternative measures, it’s essential to assess the risk and reasons why traditional malware protection mechanisms are not feasible or applicable.
(2) If traditional malware protection is unavailable, consider the proper alternative strategies and actions, such as Network Segmentation, Strict Access Controls, Regular Data Backups, Endpoint Hardening, etc.
(3) In the absence of malware protection, it's crucial to have an incident response plan in place to quickly respond to an infection.
(4) Regular monitoring and auditing are critical to identify potential threats early and ensure that mitigation measures remain effective.
(5) Maintain detailed records of the steps taken when alternative measures are implemented.

4 Description relates to 7.4.1.10-3. (SP.10.03 BR).

Provide a process that can be performed for the Asset Owner to verify the correct operation of the antimalware mechanisms at the component, systems and solution level (e.g., configuration, detection, mitigation, logging/notifications) to provide protection against known malware

When the installation of anti-virus software, based on the installation and configuration of the software, complete the configuration, detection, mitigation, and logging/notification functions in the solution of components, assets and systems, and verify the anti-virus software. correct operation of the mechanism.



5 Description relates to 7.4.1.10-4. (SP.10.04 BR).

Provide a process for the Asset Owner that can:

(1) Document and maintain the information about malware definition files;

(2) Inform the Asset Owner of the related results within a mutually agreed time period after their release by the antimalware software manufacturer

(3) Inform the Asset Owner about the applicability and approval state of the new malware definition file.

Asset owner backed anti-malware, handling master system "Active Directory" in an automated solution. For each slave management method, the status of anti-malware, including:

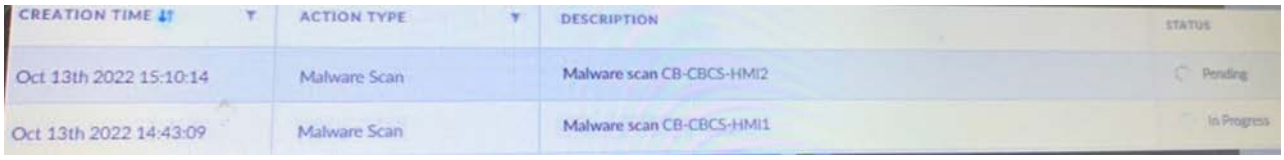
(1) Record and maintain malware definition file information.

(2) Anti-malware, the administrator evaluates and updates the virus pattern or version status of the software through the AD domain. Ensure updated software suitability and approval status.

6 Description relates to 7.4.1.10-5. (SP.10.05 BR).

Provide a process can be performed for the Asset Owner to make sure that components/workstations are free of known malware when integrated into the Automation Solution

Add a compliant and automated solution to the system process to ensure components/assets are free of known malware, Palo Alto Antivirus manually scans device assets against asset owner policies to ensure components/assets are delivered information security.



CREATION TIME	ACTION TYPE	DESCRIPTION	STATUS
Oct 13th 2022 15:10:14	Malware Scan	Malware scan CB-CBCS-HMI2	Pending
Oct 13th 2022 14:43:09	Malware Scan	Malware scan CB-CBCS-HMI1	In Progress

7 Description relates to 7.4.1.10-5. (1). (SP.10.05 RE (1)).
Provide a process can be performed for the Asset Owner to make sure portable media is used only for its intended purpose if applicable

Secure components/assets for portable media in automation solutions, Palo Alto Antivirus manually scans device assets against asset owner policies.

8 Description relates to 7.4.1.10-5. (2). (SP.10.05 RE (2)).
Provide a process for the Asset Owner to make sure that portable media are free of malware when used in the Automation Solution if applicable

For portable media in an automated solution, the asset owner provides anti-malware software. After installation, the software configuration settings and periodic scans should be performed to verify the security of the components.

4.2 Malicious Code Prevention

This requirement is related to IEC 62443-2-4 SP.03.05 BR (Hardening) which related to end point protection and management of IACS Automation Solutions.
Provide a process can be performed for the Asset Owner to:

- Reduce the attack surface of components/devices used in the Solution at least according to the points 1) to 5) of the requirement:
  (1) unnecessary software applications and services (e.g., email, office applications, games) and their associated communication access points (e.g., TCP/UDP ports), Universal Serial Bus (USB) devices (e.g., mass storage), Bluetooth and wireless communications are disabled and/or removed unless required by the Automation Solution;
  (2) network addresses in use are authorized;
  (3) physical and logical access to diagnostic and configuration ports is protected from unauthorized access and use;
  (4) unused ports on network devices (e.g., switches and routers) are configured to prevent unauthorized access to the Automation Solution's network infrastructure; and
  (5) maintenance processes maintain the hardened state of the Automation Solution during its lifetime.
- Ensure that the initial reduction of the attack surface is not weakened during maintenance procedures

Show your hardening practice and checklist used and show your hardening results as references evidence in this section.

1 Description relates to 7.4.1.2-3. (SP.03.05) BR (Hardening) Endpoint Protection Device; Please describe any Endpoint Protection Device that has been designed, installed, and configured, such as Firewall, Gateway with Firewall, IDS, etc.

Provide asset owners with a process they can follow to:

(1) Reduce the attack surface of the components/devices used in the solution according to the following points below

Unnecessary software applications and services (e.g. email, office applications, games) and their associated communication access points (e.g. TCP/UDP ports), Universal Serial Bus (USB) devices (e.g. mass storage), Bluetooth, and wireless communications are disabled and/or removed unless required by the automation solution.

All network communication equipment assets, configuration network addresses and identities (MAC addresses) can be allowed through the Netcom equipment (such as: network switches, routers) provided by the asset owner through the whitelist settings, and related documents Simple Network Diagram and Inventory Asset List

Item	Asset Name	IP address	Subnet Mask	Default Gateway
1	Server	XX.XXX.XX.XX	XXX.XXX.XXX.XXX	XX.XXX.XX.X

Physical and logical access to the diagnostic and configuration ports are protected physically or logically to prevent unauthorized access and use; the first line of defense is established for personnel identification and physical control methods, and the asset hardening report mentions physical hardening and Logical hardening (such as: cabinet locking, account password authority management, and logical hardening of open ports to prevent unauthorized access and use.

Configure unused ports on network equipment (such as switches and routers) to prevent unauthorized access to the network infrastructure of the automation solution. It is effective for asset owners to set up whitelist identification for network equipment assets. Block unauthorized connections.

The maintenance process maintains the hardened state of the automation solution during its life cycle, all maintenance processes must be carried out in accordance with its relevant regulations, carried out under the approval condition, and the "Splunk Agent Alternative" software will be installed on the asset. Security log for management and control.

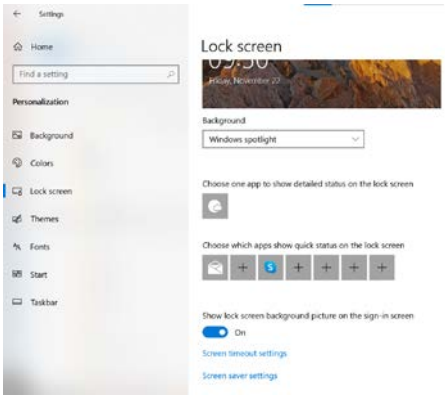
Ensure that the initial reduction of the attack surface is not weakened during maintenance procedures.

4.3 Endpoint Protection Device

Please describe any Endpoint Protection Device that has been designed, installed, and

configured, such as Firewall, Gateway with Firewall, IDS, etc.
The network communication components/assets are provided by the asset owner. Two routers are installed to whitelist the network for isolation protection.
The server equipment is suitable for endpoint protection.

1 Description relates to 7.4.1.2. (SP.03.06 BR).
The automatic screen locking configuration is shown as below :



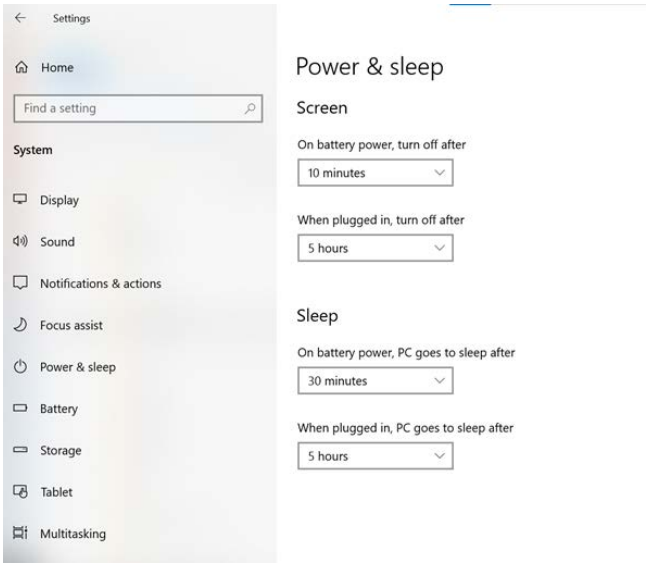
Goto the Windows Settings -> Personalization, Select “Lock screen” :
Enable screen saver:

(1) Passwords protect the screen saver — prompts to enter a password to unlock a computer

Screen saver timeout – sets time in seconds when a screen saver will be enabled, and a computer will be locked if a user is inactive

Force specific screen saver – you may specify a screen saver file to be used. The most often it is scrnsave.scr

Prevent changing screen saver – prevents users from changing screen saver settings



4.4 Data Protection in Device

Description relates to 7.4.1.2-10. (SP.03.10BR, SP.03.10 RE (1), SP.03.10 RE (2), SP.03.10 RE (3), and SP.03.08 RE (2) for Data Protection;

For sensitive data (ex. password, key, configuration/setting files/security log, etc.), please describe:

- Data storage points and dataflows within the Automation Solution that require safeguarding, as defined or approved by the asset owner
- The security requirements for their safeguarding (e.g. confidentiality, integrity, availability).
- Protect data within the Automation Solution requiring safeguarding from unauthorized disclosure or modification, whether at rest or in transit.
- The retention capabilities provided by the Automation Solution for storing/archiving sensitive data. This documentation includes capacities, pruning and purging functions, retention timeouts, etc.
- The cryptographic mechanisms, including algorithms and key management/distribution/protection, that are commonly accepted by both the security and industrial automation communities

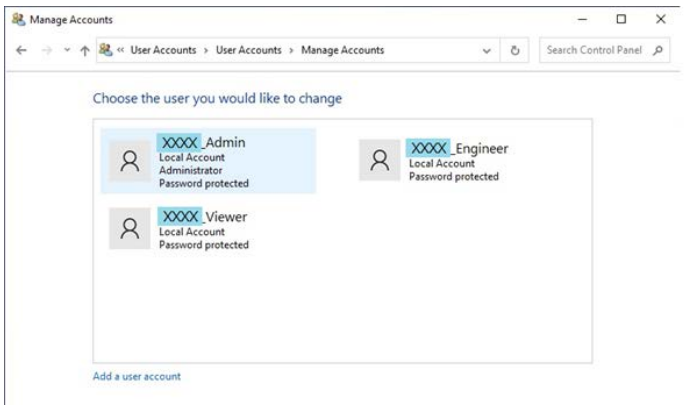
Show your hardening practice and checklist used and show your hardening results as references evidence in this section if appropriate.
Show your Account Control List and policy as references evidence.
User Policy Enforcement is the process of managing network and application connectivity, access, and use according to one or more policies defining the conditions under which access is allowed.

Please describe any policy or recommended practice applicable to SuC regarding User Policy Enforcements in this section, if any.

1 Description relates to 7.4.1.2.-10. (SP.03.10BR).

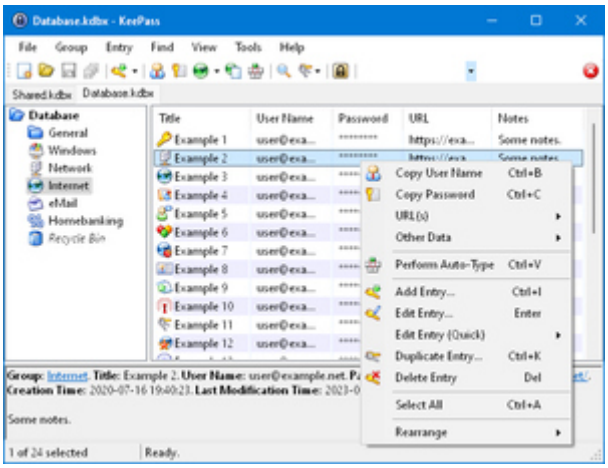
For account management, all default account needs to be deleted or changed the name, only 3 accounts are allowed to exist on the host, and the names could be set as “XXXX_Admin”, “XXXX_Engineer” and “XXXX_Viewer” to be different from the default name

A keepass tool need to be used to protect the password data file in storage and using.



2 Description relates to 7.4.1.2.-10. (1) (SP.03.10RE (1)).

KeePass is a free open-source password manager, which helps you to manage your passwords in a secure way. You can store all your passwords in one database, which is locked with a master key. So, you only have to remember one single master key to unlock the whole database. Database files are encrypted using the best and most secure encryption algorithms currently known (AES-256, ChaCha20 and Twofish).



(https://keepass.info/index.html)

3 Description relates to 7.4.1.2.-10. (2). (SP.03.10RE (2)).

For protection of the log events, Windows security logs were protected by administrator. The server should be joined into windows AD, only administrator can access the security logs. All other accounts are denied accessing the security logs.

4 Description relates to 7.4.1.2.-10. (3). (SP.03.10RE (3)).

For Database Encryption of keepass tool:

KeePass database files are encrypted. KeePass encrypts the whole database, i.e. not only your passwords, but also your usernames, URLs, notes, etc (https://keepass.info/help/base/security.html).

The following encryption algorithms are supported:

- KeePass 1.x:

Algorithm	Key Size	Std. / Ref.
Advanced Encryption Standard (AES / Rijndael)	256 bits	NIST FIPS 197
Twofish	256 bits	Info

- KeePass 2.x:

Algorithm	Key Size	Std. / Ref.
Advanced Encryption Standard (AES / Rijndael)	256 bits	NIST FIPS 197
ChaCha20	256 bits	RFC 8439
There exist various plugins that provide support for additional encryption algorithms, including but not limited to Twofish, Serpent and GOST.		

There exist various plugins that provide support for additional encryption algorithms, including but not limited to Twofish, Serpent and GOST.

These well-known and thoroughly analyzed algorithms are considered to be very secure. AES (Rijndael) became effective as a U.S. federal government standard and is approved by the National Security Agency (NSA) for top secret information. Twofish was one of the other four AES finalists. ChaCha20 is the successor of the Salsa20 algorithm (which is included in the eSTREAM portfolio).

The block ciphers are used in the Cipher Block Chaining (CBC) block cipher mode. In CBC mode, plain text patterns are concealed.
An initialization vector (IV) is generated randomly each time a database is saved. Thus, multiple databases encrypted with the same master key (e.g. backups) are no problem.

Data authenticity and integrity:

- KeePass 1.x Only: The authenticity and integrity of the data is ensured using a SHA-256 hash of the plaintext.
- KeePass 2.x Only: The authenticity and integrity of the data is ensured using a HMAC-SHA-256 hash of the ciphertext (Encrypt-then-MAC scheme).
- See also:
- KDBX file format specification.
- FIPS mode support.

Key Hashing and Key Derivation

SHA-256 is used for compressing the components of the master key (consisting of a master password, a key file, a Windows user account key and/or a key provided by a plugin) to a 256-bit key K.
SHA-256 is a cryptographic hash function that is considered to be very secure. It has been standardized in NIST FIPS 180-4. The attack against SHA-1 discovered in 2005 does not affect the security of SHA-256.
In order to generate the key for the encryption algorithm, K is transformed using a key derivation function (with a random salt). This prevents precomputation of keys and makes dictionary and guessing attack harder. For details, see the section 'Protection against Dictionary Attacks'.

Protection against Dictionary Attacks

KeePass features protection against dictionary and guessing attacks.
Such attacks cannot be prevented, but they can be made harder. For this, the key K derived from the user's master key (see above) is transformed using a key derivation function with a random salt. This prevents a precomputation of keys and adds a work factor that the user can make as large as desired to increase the computational effort of a dictionary or guessing attack.
Multiple key derivation functions are supported. In the database settings dialog, you can select one and specify certain parameters for it.
By clicking the '1 Second Delay' button in the database settings dialog, KeePass computes the number of iterations that results in a 1 second delay when loading/saving a database. Furthermore, KeePass 2.x has a button 'Test' that performs a key transformation with the specified parameters (which can be cancelled) and reports the required time. The key transformation may require more or less time on other devices. If you are using KeePass or a port of it on other devices, make sure that all devices are fast enough (and have sufficient memory) to load the database with your parameters within an acceptable time.

5 Description relates to 7.4.1.2.-8(2). (SP.03.08BR (2)).
To show the protection methods for data in the device.

(Protection method)		SCADA system			Safety Control system	Configuration & Auxiliary management system
Data to protect	Security group AD	SCADA HM	IED (Control)	Ethernet Switch	IED (Protection)	Wireless AP (could be connected to a laptop)
Configuration file		AES		User Control		
IAM database						
Sensitive Log						

4.5 Disposal of Systems and Devices

1 Description relates to 6.5.3.2 and 6.5.3.3. (SP.03.10RE (4)).
Decommissioning/replacement of hardware/software components in the SuC:
(1) data storage points and dataflows within the Automation Solution that require safeguarding,
(2) the security implements for their safeguarding (e.g. confidentiality, integrity, availability).
Disposed components must be removed for the configuration of SuC configuration

5.0 Hardening Control

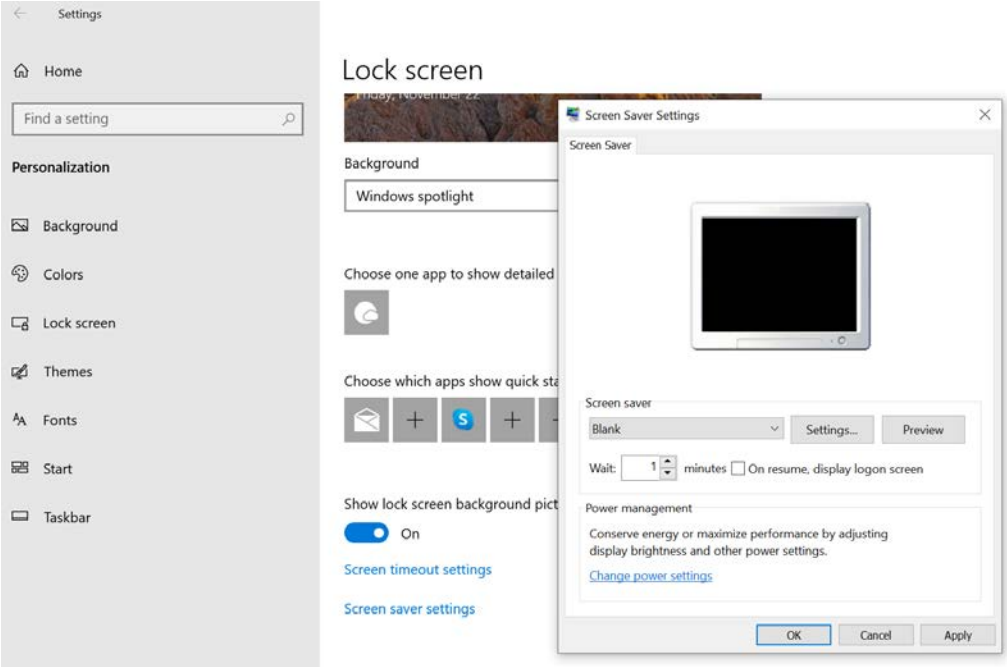
List of subsystems or assets to which this security measures/countermeasures apply.
Hardening control, applicable to all types of asset equipment, components/assets provided by equipment suppliers.

5.1 Application and User Hardening Management

This requirement is related to IEC 62443-2-4 SP.03.05 BR (Hardening) which related to Components and/or Devices of IACS Automation Solutions.
Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.2-3. (SP.03.05 BR) (Hardening) Identity and Access Management (IAM)
Reduce the attack surface of components/devices used in the Solution at least according to the points 1) to 5) of the requirement:

(1) unnecessary software applications and services (e.g., email, office applications, games) and their associated communication access points (e.g., TCP/UDP ports), USB devices (e.g., mass storage), Bluetooth and wireless communications are disabled and/or removed unless required by the Automation Solution;



(2) network addresses in use are authorized;

(3) physical and logical access to diagnostic and configuration ports is protected from unauthorized access and use;

(4) unused ports on network devices (e.g., switches and routers) are configured to prevent unauthorized access to the Automation Solution's network infrastructure; and

(5) maintenance processes maintain the hardened state of the Automation Solution during its lifetime.

Ensure that the initial reduction of the attack surface is not weakened during maintenance procedures

Show your hardening practice and checklist used and show your hardening results as references evidence in this section.
Refer to Dummy Project - Asset Hardening Recommended Practices.pdf

5.2 Certificate Authority (CA) Management

This requirement is related to IEC 62443-2-4 SP.03.05 RE (1) (CA Hardening) which related to Components and/or Devices of IACS Automation Solutions.

1 Description relates to 7.4.1.2-4. (SP.03.05 RE (1) (CA Hardening) Manage that only necessary, authorized, and documented Certificate Authority(CA) digital certificates are installed

Requirement: The service provider establishes a process that enables asset owners to verify that the digital certificate installed on the Windows PC/host is a required, authorized, and documented CA credential.
Here are a few ways to meet this requirement, and you can choose the right solution based on the actual situation and the customer's needs, and integrate it into a set of process documents:

(1) Manual inspection and documentation

a Steps:

(a) Open the Certificate Manager:
- Enter "certmgr.msc" in the Windows search bar to turn on Native User Certificate Administrator.
- To check your local PC credentials, execute certlm.msc as a system administrator.

(b) Check the certificate store:
- Typical certificate storage areas that need to be checked include "Trusted Root Certification Authority", "Certificate Authorized Entity", "Trusted Publishers", and "Corporate trust" (if any).

(c) Check the certificates one by one:
- Check that the Issuer of each credential is a known and trusted CA.
- Check whether the validity period of the voucher is valid.
- Check that the credential is being used as intended.

(d) Record the results of the examination:
- Create a document, such as an Excel spreadsheet, that records the following information for each certificate, include Certificate Name (Subject), Issuer, Serial Number, Thumbprint, Validity (Valid From, Valid To), Intended Purposes, Necessary, Authorized, and Notes—Record any unusual or documents that require further investigation.

(e) (Not required) ** Screenshot of the voucher and display it in the report

b Pros: Simple and easy to understand, no additional tools required.

c Cons: Time-consuming, error-prone, and not suitable for large-scale deployments.

(2) Use PowerShell scripts

a Example script (get all trusted root CAs):
powershell Get-ChildItem -Path Cert:\LocalMachine\Root | Format-List

b You can write more advanced PowerShell scripts to:

(a) Automatically check credentials in a specific vault.

(b) Filter for credentials with specific criteria (e.g., expired credentials, unknown publishers).

(c) Output the results of the inspection to a file (e.g., CSV, HTML).

(d) Provide more detailed credential information:

- Pros: Fast, automatable, repeatable execution.
- Cons: Requires PowerShell scripting skills.

(3) Use third-party tools

a There are third-party tools that can help manage and audit certificates, such as:

(a) KeyStore Explorer: https://keystore-explorer.org/

(b) XCA (X Certificate and Key Management): https://hohnstaedt.de/xca/

(c) Microsoft Sysinternals Sigcheck: https://learn.microsoft.com/en-us/sysinternals/downloads/sigcheck

b These tools typically offer friendlier interfaces, more powerful search and filtering capabilities, and reporting capabilities.

c Pros: Powerful and user-friendly.

d Cons: Additional costs may be required (depending on the tool).

(4) Create a Certificate Baseline

a Create an Initial Baseline :

(a) Once the system has been installed and the necessary credentials have been set, use one of the above methods to create a "clean" certificate list (baseline).

b Periodic Matching:

(a) Perform regular checks to compare the current list of documents against the benchmark.

(b) Any new, deleted, or modified credentials should be recorded and reviewed.

c Automation (optional):

(a) Use PowerShell scripts or third-party tools to automate comparisons and reports.

(5) Check Certificate (CA) with Baseline

a Verify that only necessary, authorized, and documented Certificate Authority (CA) digital certificates are installed. Once an unnecessary certificate is found, it needs to be deleted.

(6) Manage the Certificate (CA)

a The procedures for Add/Delete/Update a Certificate Authority (CA). This operation should only be limited and protected under Administrator role to execute.

6.0 Identity and Access Management (IAM)

List of subsystems or assets to which this security measures/countermeasures apply.
For the management of identity and access, all communication equipment is controlled by locks.
The SuC room needs to recognize the door opening authority.
Account control of assets, Identity and Access Management (IAM) by Active Directory is based on policies and procedures.

6.1 Use Control and Least Functionality Settings

This requirement is related to IEC 62443-2-4 SP.03.08 BR.
Provide a process can be performed for the Asset Owner to:

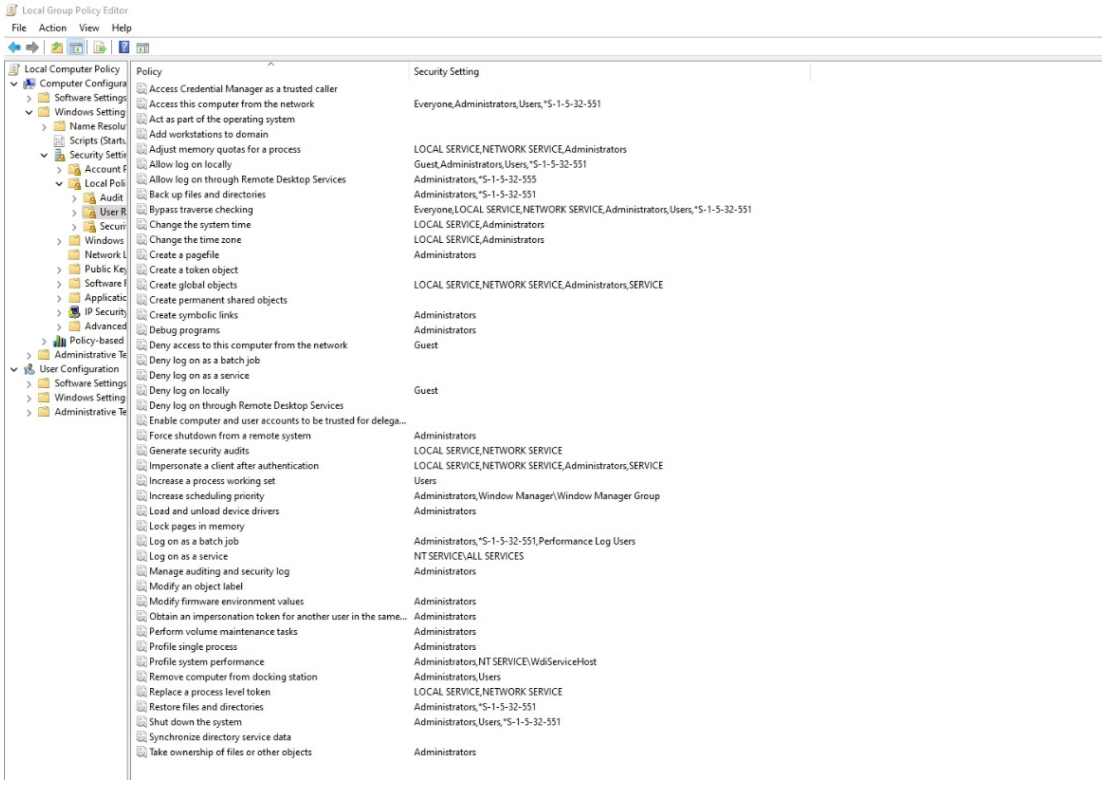
- Identify the mechanisms used to enforce least privilege (e.g., role-based access controls) in network devices
- Configure and validate least privilege for the administration of network devices

1 Description relates to 7.4.1.2-8. (SP.03.08 BR).
In the automation solution, the assets based on the Windows system will be managed according to the RBAC method and the asset account will be classified into categories.
In order to formulate the required control management, Window OS divides accounts into four main categories.

(1) Admin account integrated into Active Directory management
Emergency Response Administrator Account
The account of the on-duty maintenance engineer of the asset owner
Supplier maintenance engineer account

(2) Device vendors ensure that Active Directory supervises all activities during the maintenance configuration process. And according to the application project, the personnel are arranged and managed.

(3) User permission settings:



6.2 Internal and External User Access Controls

This requirement is related to IEC 62443-2-4 SP.07.01 BR, SP.07.02 BR, SP.07.03 BR, SP.07.04 BR, and SP.07.04 RE (1) which related to internal and external user access controls.

If applicable with remote access applications, provide a process that can be performed for the Asset Owner to:

This requirement is related to IEC 62443-2-4 SP.07.01 BR, SP.07.02 BR, SP.07.03 BR, SP.07.04 BR and SP.07.04 RE (1) related to internal and external user access control.

In automation solutions, subsystems in Windows-based assets.

For centralized service requirements, it needs to be integrated according to "Active Directory" and "DC", DC/AD should be integrated according to policy and procedure. Technical implementation will also enable internal processes for user creation, monitoring, auditing, profile changes, deletions, etc.

In this system, external access control is prohibited without the permission of the asset owner. All access controls should be logged into the system locally. The following figure shows a schematic diagram of the network framework in the system and a list of asset users, indicating that all asset items should follow this policy.

1 Description relates to 7.4.1.8-1. (SP.07.01 BR).

(1) Identify remote access applications that it has approved for use in its Solutions;

(2) Systematically select and approve them; and

(3) Verify that they are commonly accepted.

(4) Identify remote access login requirements for the remote access applications it has approved for use in its solution.

(5) A Remote PC Access (Citrix Virtual Apps and Desktops) or FortiGate IPSec VPN could be used to implement the remote access security. These applications are commonly accepted for remote access solutions.

(6) The User Access Controls should be integrated with Active Directory (AD) for Windows domain networks.

2 Description relates to 7.4.1.8-2. (SP.07.02 BR).

Provide/refer to a user manual that includes the description to install/configure, operate, and terminate the remote access application

According to the software user manual, should refer to the user manual for remote access application installation/configuration, operation, and termination description

3 Description relates to 7.4.1.8-3. (SP.07.03 BR).

Identify and describe each remote access connection proposed for the solution, covering all demand points. Provide the asset owner with information about all suggested remote access connections, including, for each connection:

(1) its purpose;

(2) the remote access application to be used;

(3) how the connection will be established (e.g., via the Internet through a VPN); and

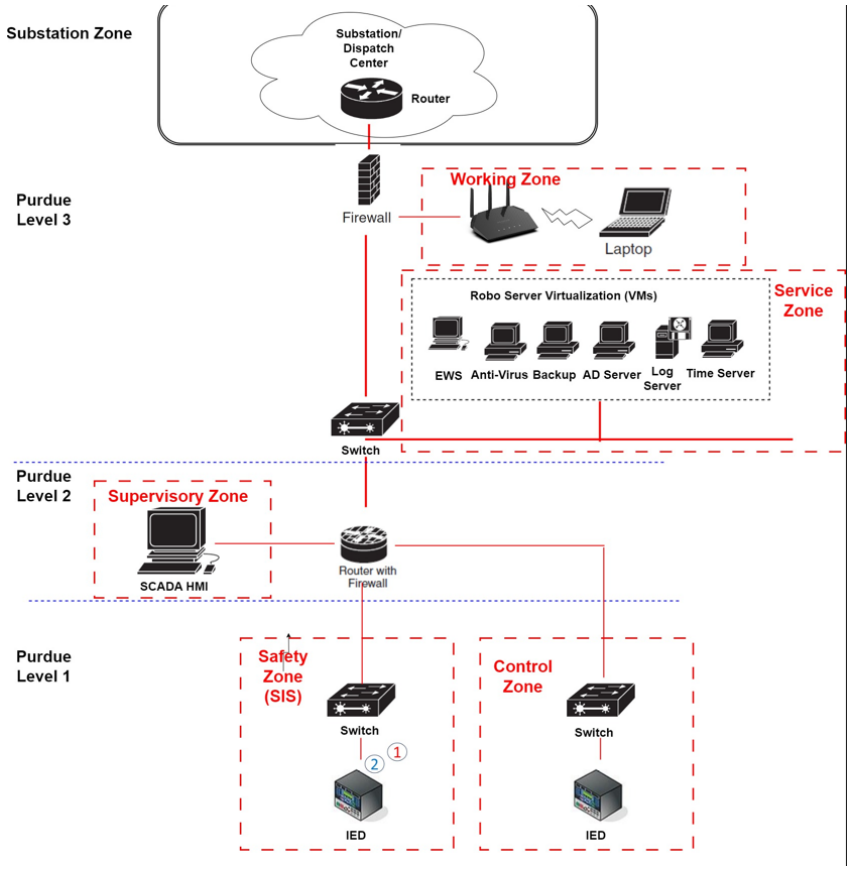
(4) the location and identity of the remote client.

The following remote access connection application could be used, referring to ID05 section 5.3.

Remote Access Connection Application			
Purpose			
Access Method	System or device: Account: such as Engineer, viewer Source: IP Address Protocol or software: Multi-factor Authentication:		
Duration of Access	Start: Date and Time End: Date and Time		
Applicant	Team:	Company:	Name:
	Job Title	Email	Phone
Approve	Target Department	Job Title	Name: Sign with date
	IT/OT Operating Team	Job Title	Name: Sign with date

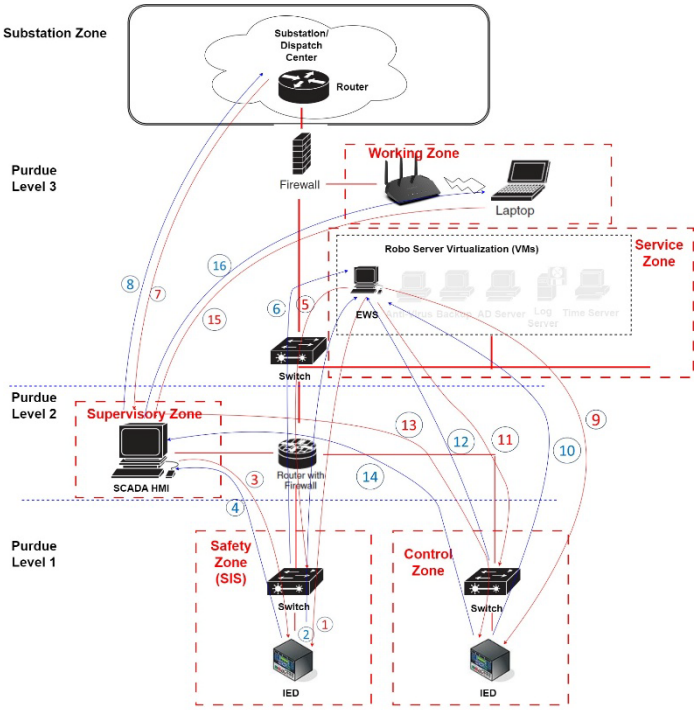
6.3 Network Assess Controls

This requirement is related to IEC 62443-2-4 SP.03.02 BR, SP.03.07 BR, SP.03.02 RE (1), SP.03.02 RE (2), SP.07.01 BR, SP.07.02 BR, SP.07.03 BR, SP.07.04 BR, and SP.07.04 RE (1) which related to network assess controls.



In the automation solution, network access control is provided by Citrix solution, which enables network communication components/assets, risk assessment and communication methods. For more information, see Simple Network Diaram and Data Flow Diagram.

Please refer to the following figures for the introduction:



Provide a process that can be performed for the Asset Owner to:

1 Description relates to 7.4.1.2-1. (SP.03.02 BR).
Ensure that the physical network segmentation architecture used in the Automation Solution, including its use of network security devices or equivalent mechanisms, is implemented according to the Automation Solution design approved by the Asset Owner

2 Description relates to 7.3.1.1-4. (1) (SP.03.02 RE (1)).
Identify and document the network segments of the Automation Solution and their interfaces to other segments, including external networks, and for each interface designate whether it is trusted or untrusted

3 Description relates to 7.3.1.1-4. (2) & (3). (SP.03.02 RE (2)).
Ensure that interfaces of the Automation Solution that have been identified as untrusted are protected by network security devices or equivalent mechanisms, with documented and maintained security rules. At a minimum, the following shall be protected:
(1) external interfaces;
(2) level 2/Level 3 interfaces;
(3) interfaces between the Basic Process Control System (BPCS) and the SIS
(4) interfaces connecting wired and wireless BPCS networks
(5) interfaces connecting the BPCS to data warehouses (e.g., enterprise historians)

4 Description relates to 7.4.1.2-6. (SP.03.07 BR)

(1) It should implement the access controls (including authentication mechanisms) in accordance with PE/O policies or the Security Policies and Procedures Management Plan to minimize security risks. For example, Windows AD could be used for Windows-based hosts in SuC, and Cisco RADIUS or Cisco TACACS+ could be used for IACS devices in SuC, if applicable.

(2) Ensure that these mechanisms prevent unauthorized access to the control devices by workstations and handhelds.

(3) Communication security safeguards (e.g. network security devices) at the SuC boundary with Level 3. For example, a firewall or managed switch could be used to manage the connection authority limitation for the assets in the SuC's network.

(4) It should avoid direct access to these devices by handhelds that bypass access controls of the SuC. It should avoid direct access by a handheld to a wireless device in Level 3 that bypasses the Level 2/3 communication security device.

If applicable with remote access applications, provide a process that can be performed for the Asset Owner to:

5 Description relates to 7.4.1.8-1. (SP.07.01 BR).

Identify remote access applications that it has approved for use in its Solutions;
Systematically select and approve them; and
Verify that they are commonly accepted.

6 Description relates to 7.4.1.8-2. (SP.07.02 BR).

Provide/refer to a user manual that includes the description to install/configure, operate, and terminate the remote access application

7 Description relates to 7.4.1.8-3. (SP.07.03 BR).

Identify and describe each remote access connection proposed for the Solution covering all points of the requirement. Provide information about all proposed remote access connections to the Asset Owner that includes, for each connection:

(1) its purpose;

(2) the remote access application to be used;

(3) how the connection will be established (e.g., via the Internet through a VPN); and

(4) the location and identity of the remote client.

8 Description relates to 7.4.1.8-4. (SP.07.04 BR).

Ensure that it obtains approval from the Asset Owner prior to using each and every remote access connection.

9 Description relates to 7.4.1.8-5. (SP.07.04 RE (1)).

Ensure that all remote access connections conducted over the Internet or over other publicly accessible media that are used to support remote access to the Automation Solution by the Server Provider (e.g., from a Server Provider facility) are authenticated and encrypted.

6.4 Application Access Controls

This requirement is related to IEC 62443-2-4 SP.03.08 BR and SP.03.08 RE (1) which related to application assess controls.

Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.2-8. (SP.03.08 BR).
Identify the mechanisms used to enforce least privilege (e.g., role-based access controls) in network devices
Configure and validate least privilege for the administration of network devices
(1) Identify mechanisms for enforcing least privilege (e.g., user privilege-based access control) in network devices only for remote login to log user privileges to make remote changes.
(2) Ensure that component/device-based applications, login authentication, log in to the corresponding account according to the user role, and manage permissions. However, under the popular Windows operating system, it is impossible to restrict the access control rights of its account setting application.
(3) The mitigation measures are to set up different accounts under the application, which can be roughly divided into 1-level users: application monitoring and historical record query matters; 2-level operators: including 1-level user functions and control operation functions; 3-level management Staff: It includes the functions of level 2 operators, programming modification and account adjustment.

2 Description relates to 7.4.1.2-8. (1) (SP.03.08 RE (1)).
Support role-based access controls for network devices and wireless networks
Configure, validate, verify and test network devices and wireless networks to use role-based access control as required.
(1) Support role-based access control to network devices and wireless networks. This section summary does not apply to system asset devices, all assets do not support wireless networks.
(2) Use user account-based access control to configure, authenticate, authenticate, and test network devices and wireless networks as needed: This section should not apply as all devices in the system are not intended for wireless network connections to applications

3 Description relates to 7.4.1.2-8. (3) (SP.03.08 RE (3)).
To describe the used mutual authentication mechanism of the Web assess administration for communication devices. (Assess account management, mutual authentication method, connection protocol like https)

6.5 User Access Rights and Role-based Access Controls

This requirement is related to IEC 62443-2-4 SP.03.08 BR and SP.03.08 RE (1) which related to user access rights and role-based access controls.

Based on Window assets, equipment suppliers first divide users into four major categories of users

This includes the administrator privilege account used by Active Directory integration, the emergency response administrator account, the asset owner on-duty maintenance engineer account, and the supplier maintenance engineer account

The automation solution using the remote access program is controlled by AD/DC integration. After the assets are delivered, relative account users should be established based on roles with different permissions. Some systems have established an administrator account for emergency response measures.

Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.2-8. (SP.03.08 BR).

Identify the mechanisms used to enforce least privilege (e.g., role-based access controls) in network devices

Configure and validate least privilege for the administration of network devices

(1) Identify mechanisms for enforcing least privilege (eg, user privilege-based access control) in network devices for remote login only to log in user privileges to make remote changes.

(2) Ensuring minimum privileges for login authentication for Windows-based component/device management configuration

2 Description relates to 7.4.1.2-8. (1) (SP.03.08 RE (1)).

Support role-based access controls for network devices and wireless networks

Configure, validate, verify and test network devices and wireless networks to use role-based access control as required

(1) Supports role-based access control for network equipment and wireless networks. The summary in this section does not apply to system asset equipment, and all assets do not support wireless networks.

(2) Configure, verify, validate, and test network devices and wireless networks, using user account-based access controls as needed.

6.6 Access and Administration Mechanisms

This requirement is related to IEC 62443-2-4 SP.09.01 BR, SP.09.02 BR, SP.09.02 RE (1), SP.09.02 RE (4), SP.09.03 BR, SP.09.04 BR, SP.09.05 BR, SP.09.06 BR, SP.09.06 RE (1), SP.09.08 BR, SP.09.09 BR, and SP.09.09 RE (1).

Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.3.-1. (SP.09.01 BR).

(1) Ensure that account management supports the points 1) to 4) of the requirement

(2) the use of a single, integrated data base, which may be distributed or redundant, for defining and managing user and service accounts;

(3) restricted management of accounts to authorized users;

(4) decentralized access to this data base for the management of accounts;

(5) decentralized enforcement of the account settings (e.g., passwords, operating system privileges, and access control lists) defined in this data base.

(6) Make sure Asset Account Management supports the following points

- Use a single integrated database (which can be distributed or redundant) to define and manage user and service accounts. Asset account control with Windows-based System Asset Accord (RBAC) Role-based Access Controls for automated solutions. For details, please refer to the Account List below.
- For assets in automation solutions, user account management for authorized users is limited. Divided into the local system account and application account configuration, the account setting method is based on (RBAC) Role-based Access Controls as the basic design.
- Decentralized access to the database to manage accounts. After the asset is delivered, the database is kept and maintained by the asset owner, and accounts can be renamed based on RBAC requirements according to AD/DC integrated management. It is recommended to keep the database decentralized by asset type to avoid showing all authorized accounts in a single file.
- Decentralize the account settings defined in this database, and should decentralize database data (such as passwords, operating system permissions, and access control lists) when the equipment vendor delivers it to the asset owner.

Asset ID	Asset Name	SuC Name	Zone ID	Conduit ID	Installed Location	Account Classification (User, for SI/SM Service, Non-human)	Account Type (Permission/ Privileged, e.g. Guest, General User, Privileged User, Operator, Enigneer, Admin, etc.)
HW-03-001	SCADA HMI Server	Power switch control system and Networks of the substation	03 SCADA Zone	0306, 0305, 0103, 0203	Cabinet_#####	User	Operator
HW-03-001	SCADA HMI Server	Power switch control system and Networks of the substation	03 SCADA Zone	0306, 0305, 0103, 0203	Cabinet_#####	User	Admin
HW-03-001	SCADA HMI Server	Power switch control system and Networks of the substation	03 SCADA Zone	0306, 0305, 0103, 0203	Cabinet_#####	User	User

2 Description relates to 7.4.1.3.-2. (SP.09.02 BR).
Create and maintain a unique user account for each Automation Solution user
A single-user user account has been established for each automation solution asset for maintenance and use, and then the asset owner can create a personal user account to ensure that it is a single-user account according to their use needs.

3 Description relates to 7.4.1.3.-2. (1). (SP.09.02 RE (1)).
Generate a list of all user and service accounts and provide instructions to the Asset Owner that describes how to change their passwords

According to the Windows 10 system, create or change account permissions and password instructions, the following is the Microsoft Support Password Change Manual webpage https://support.microsoft.com/en-us/windows/change-or-reset-your-windows-password-8271d17c-9f9e-443f-835a-8318c8f68b9c#WindowsVersion=Windows_10

If you already know your current password and want to change it

Select **Start** > **Settings** > **Accounts** > **Sign-in options**. Under **Password**, select the **Change** button and follow the steps.

Reset your Windows 10 local account password

If you've forgotten or lost your Windows 10 password for a local account and need to sign back in to your device, the below options might help you get up and running. For more info on local standard vs. administrative accounts, see Create a local user or administrator account in Windows 10.

Windows 10 version 1803 and later

If you added security questions when you set up your local account for Windows 10, then you have at least version 1803 and you can answer security questions to sign back in.

After you've entered an incorrect password:

1. Select the **Reset password** link on the sign-in screen. If you use a PIN instead, see PIN sign-in issues. If you're using a work device that's on a network, you may not see an option to reset your password or PIN. In that case, contact your administrator.

   Note: If you don't see security questions after you select the **Reset password** link, make sure your device name isn't the same as your local user account name (the name you see when you sign in). To see your device name, right-click **Start** in the taskbar, select **System**, and scroll to the Device specifications section. If the device name is the same as your account name, you can create a new administrator account, sign in as an administrator, and then rename your PC (when you view your device name, you can also rename it).

2. Answer your security questions.
3. Enter a new password.
4. Sign in as usual with the new password.

Windows 10 before version 1803

For versions of Windows 10 earlier than 1803, local account passwords can't be reset because there are no security questions. You can reset your device to choose a new password, however this option will permanently delete your data, programs, and settings. If you've backed up your files you'll be able to restore your deleted files. For more information, see Recovery options in Windows 10.
To reset your device, which will delete data, programs, and settings:

1. Press the **Shift** key while you select the **Power** button > **Restart** in the lower-right corner of the screen.
2. On the **Choose an option** screen, select **Troubleshoot** > **Reset this PC**.
3. Select **Remove everything**.

Warning: Resetting your device will permanently delete data, programs, and settings.

4 Description relates to 7.4.1.3.-2. (4). (SP.09.02 RE (4)).
Disable the administrator account or otherwise protect it from exploitation
In the automation solution, when the asset is delivered to the asset owner, AD/DC integrates all role accounts and generates the required user accounts and appropriate permissions to protect the assets from being exploited.

5 Description relates to 7.4.1.3.-3. (Description relates to. (SP.09.03 BR).
Identify and remove/disable the unused system default accounts
Assets for automation solutions, removal of unused default accounts, and verification of the project ensure all users are encrypted and controlled.

6 Description relates to 7.4.1.3.-4. (SP.09.04 BR).
Identify and remove/disable the user accounts that are no longer needed through the proper validation (operating) steps of the automation solution for inspection to ensure.
For the automation solution, in order to respond to emergency situations and restore the operation of the system, an Emergency Response administrator account can be created for key system assets to facilitate the RPO Target in system backup and restoration.

7 Description relates to 7.4.1.3.-5. (SP.09.05 BR).
Identify the account management application(s) used to set password policies that meet this requirement. Show that they are commonly accepted
System automation solution assets, set up account management applications according to the password policy principle, all passwords meet the complexity of uppercase and lowercase English, numbers and symbols, and according to the password rules, the passwords for user accounts with different privileges are different from 12 to 36 characters. And re-adjusted by DC/AD Group Policy etc. after asset delivery.

8 Description relates to 7.4.1.3.-6. (SP.09.06 BR).

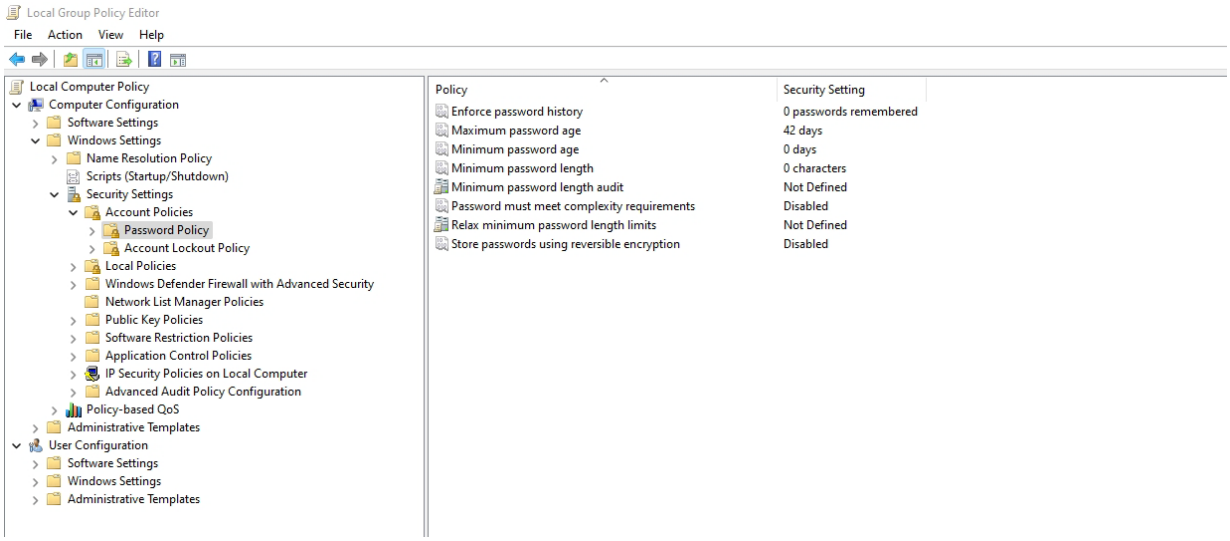
(1) Retrieve the expiry period requirements from the Asset Owner

(2) Configure password expiry to meet those requirements

Note: Defining an expiration period to “infinite” (no expiry) is a possible choice for the Asset Owner.

In the automation solution, the account authority of the asset sets the password validity period according to the asset owner password rule to define the password to be updated regularly.

In Windows system, users with the same authority can only set a single expiration time. The DC/AD management account and emergency response administrator account with system permissions are set to 360 days, and the password expiration date of other users is 180 days. "gpedit.msc" enters the local rules to edit the password settings. Refer to Figure below:

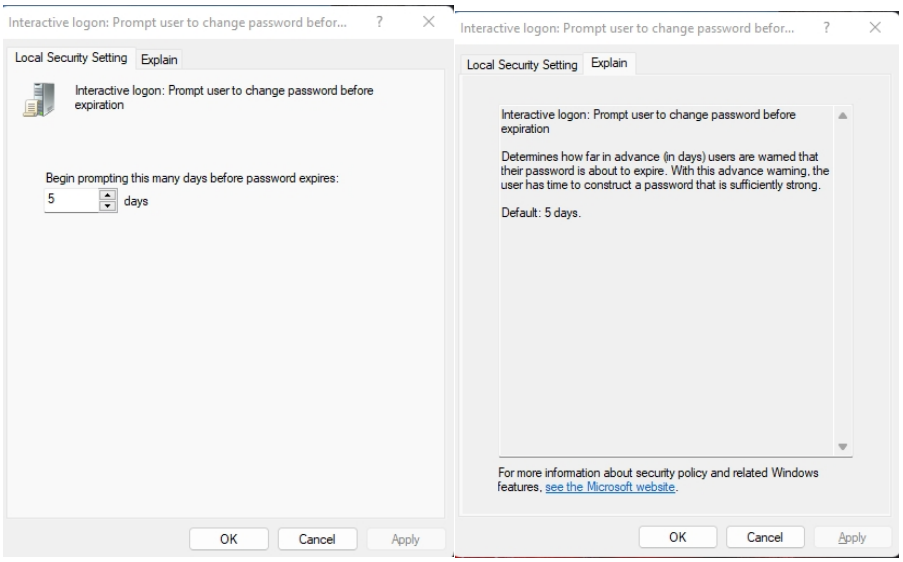


9 Description relates to 7.4.1.3.-6. (1). (SP.09.06 RE (1)).

(1) Retrieve the number of days for prompting users before password expiry from the Asset Owner

(2) Configure password expiry to meet that requirement

(3) In the automation solution, the number of days to prompt the user to change the configuration password before the asset account password expires has met this requirement. The following figures are shown the validation step of Microsoft Windows AD for this requirement.



10 Description relates to 7.4.1.3.-8. (SP.09.08 BR).

(1) Retrieve the number “N” of passwords from the Asset Owner

(2) Configure password reuse to meet the related requirements

(3) In the automated solution, after the asset owner changes the password, only the asset owner can obtain "N" passwords through application, and the relevant regulations on the use of passwords must be subject to the asset owner.

11 Description relates to 7.4.1.3.-9. (SP.09.09 BR).

(1) Retrieve passwords approved for sharing from the Asset Owner

(2) Document and maintain retrieved passwords securely

(3) In an automated solution, when the asset owner changes the password, the shared password can only be obtained through application and approval by the asset owner. Regulations regarding the use of passwords must be based on the asset owner, and responsibility for custody of retrieved passwords must be securely recorded and maintained.

(4) A keepass tool need to be used to protect the password data file in storage and using. It stores all passwords in a locally encrypted database, which is protected by a master password or a key file.

12 Description relates to 7.4.1.3.-9. (1). (SP.09.09 RE (1)).

(1) Cooperate with the asset owner to modify the relevant password. User Policy Enforcement

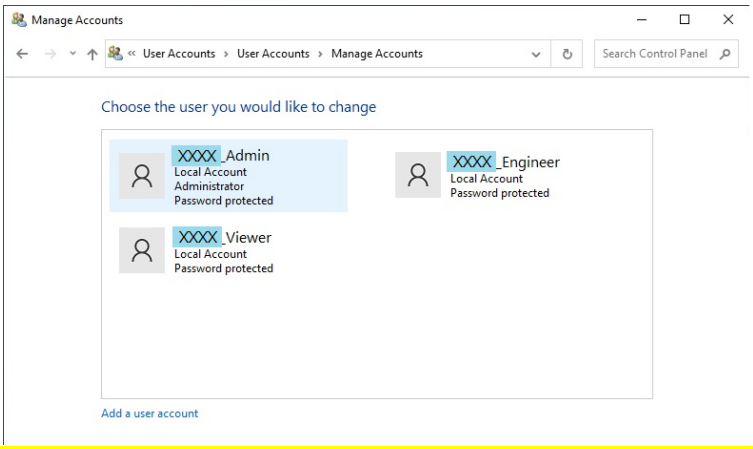
(2) User policy enforcement is the process of managing network and application connections, access, and usage according to one or more policies that define the conditions for allowing access.

(3) In the automated solution, the identification of the team management personnel is managed by the personnel who apply for permission through the work order, but not only depends on personnel control, but also includes the whitening of the network communication assets with the asset owner IT department at the network

level. List hardening, asset device type hardening, other asset addition hardening of automation solutions in the process of application connection or use.

6.7 User Policy Enforcement

Show your hardening practice and checklist used and show your hardening results as references evidence in this section if appropriate.
Show your Account Control List and policy as references evidence.
User Policy Enforcement is the process of managing network and application



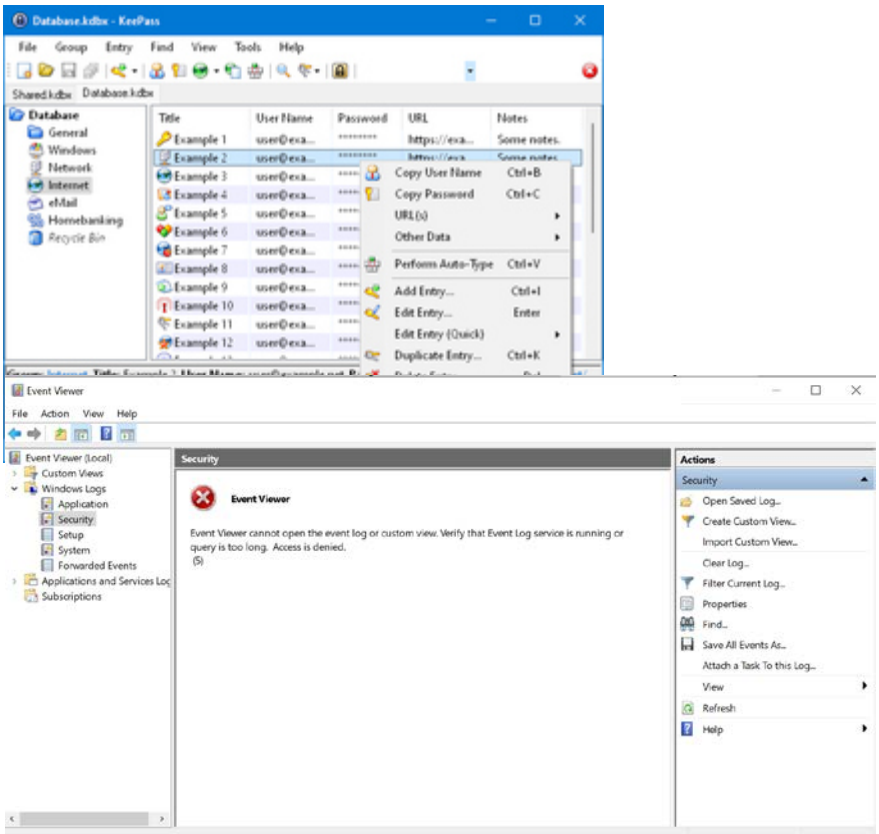
connectivity, access, and use according to one or more policies defining the conditions under which access is allowed.
Please describe any policy or recommended practice applicable to SuC regarding User Policy Enforcements in this section, if any.

1 Description relates to 7.4.1.3.-7. (SP.09.07BR).
For account management, all default account need to be deleted or changed the name, Only 3 accounts are allowed to exist on the host, and the names could be set as “XXXX_Admin”, “XXXX_Engineer” and “XXXX_Viewer” to be different from the default name.

A keepass tool need to be used to protect the password data file in storage and using.

2 Description relates to 7.4.1.3.-8.(1) SP.09.08RE(1)
Description to prevent users from changing their passwords more frequently than once every N days. (增加 GPO 中 顯示多久變更密碼的訊息畫面)

3 Description relates to 7.4.1.2.-10. (SP.03.10BR).



KeePass is a free open-source password manager, which helps you to manage your passwords in a secure way. You can store all your passwords in one database, which is locked with a master key. So, you only have to remember one single master key to unlock the whole database. Database files are encrypted using the best and most secure encryption algorithms currently known (AES-256, ChaCha20 and Twofish).

(https://keepass.info/index.html)

4 Description relates to 7.4.1.2.-10. (2). (SP.03.10RE (2)).

For protection of the log events, Windows security logs were protected by administrator. The server should be joined into windows AD, only administrator can access the security logs. All other accounts are denied accessing the security logs.

5 Description relates to 7.4.1.2.-10. (3). (SP.03.10RE (3)).

(https://keepass.info/help/base/security.html)

- For Database Encryption of keepass tool:

  KeePass database files are encrypted. KeePass encrypts the whole database, i.e. not only your passwords, but also your usernames, URLs, notes, etc.

  The following encryption algorithms are supported:

Algorithm	Key Size	Std. / Ref.
Advanced Encryption Standard (AES / Rijndael)	256 bits	NIST FIPS 197
ChaCha20	256 bits	RFC 8439
There exist various plugins that provide support for additional encryption algorithms, including but not limited to Twofish, Serpent and GOST.		

KeePass 1.x:

KeePass 2.x:

There exist various plugins that provide support for additional encryption algorithms, including but not limited to Twofish, Serpent and GOST.
These well-known and thoroughly analyzed algorithms are considered to be very secure. AES (Rijndael) became effective as a U.S. federal government standard and is approved by the National Security Agency (NSA) for top secret information. Twofish was one of the other four AES finalists. ChaCha20 is the successor of the Salsa20 algorithm (which is included in the eSTREAM portfolio).
The block ciphers are used in the Cipher Block Chaining (CBC) block cipher mode. In CBC mode, plain text patterns are concealed.
An initialization vector (IV) is generated randomly each time a database is saved. Thus, multiple databases encrypted with the same master key (e.g. backups) are no problem.
Data authenticity and integrity:

KeePass 1.x Only : The authenticity and integrity of the data is ensured using a SHA-256 hash of the plaintext.
KeePass 2.x Only : The authenticity and integrity of the data is ensured using a HMAC-SHA-256 hash of the ciphertext (Encrypt-then-MAC scheme).

See also:

KDBX file format specification.
FIPS mode support.

- Key Hashing and Key Derivation

  SHA-256 is used for compressing the components of the master key (consisting of a master password, a key file, a Windows user account key and/or a key provided by a plugin) to a 256-bit key K.
  SHA-256 is a cryptographic hash function that is considered to be very secure. It has been standardized in NIST FIPS 180-4. The attack against SHA-1 discovered in 2005 does not affect the security of SHA-256.
  In order to generate the key for the encryption algorithm, K is transformed using a key derivation function (with a random salt). This prevents precomputation of keys and makes dictionary and guessing attack harder. For details, see the section 'Protection against Dictionary Attacks'.

- Protection against Dictionary Attacks

  KeePass features protection against dictionary and guessing attacks.

Such attacks cannot be prevented, but they can be made harder. For this, the key K derived from the user's master key (see above) is transformed using a key derivation function with a random salt. This prevents a precomputation of keys and adds a work factor that the user can make as large as desired to increase the computational effort of a dictionary or guessing attack.
Multiple key derivation functions are supported. In the database settings dialog, you can select one and specify certain parameters for it.
By clicking the '1 Second Delay' button in the database settings dialog, KeePass computes the number of iterations that results in a 1 second delay when loading/saving a database. Furthermore, KeePass 2.x has a button 'Test' that performs a key transformation with the specified parameters (which can be cancelled) and reports the required time.
The key transformation may require more or less time on other devices. If you are using KeePass or a port of it on other devices, make sure that all devices are fast enough (and have sufficient memory) to load the database with your parameters within an acceptable time.

7.0 Security Patching

List of subsystems or assets to which this security measures/countermeasures apply.
Patches are generally to deal with the vulnerabilities existing in the computer, in order to better optimize the performance of the computer. According to the size of its impact, it can be divided into:

1. Patches for "high-risk vulnerabilities", which may be exploited by Trojans and viruses, and should be fixed immediately.
2. The software security update patches are used to fix serious security holes in some popular software, and it is recommended to fix them immediately.
3. Optional high-risk vulnerability patches, which may cause the computer and software to fail to work normally after installation and should be selected carefully.
4. Other and functional update patches are mainly used to update the functions of the system or software and can be selectively installed as needed.
5. Invalid patches can be divided into:
   (1) Expired patches. These patches may be replaced by other patches because they were not installed in time and do not need to be installed again.
   (2) Ignored patches, which are checked before installation and found to be unsuitable for the current system environment, are ignored by the patch software intelligently.

The patch has been banned, and it has been intelligently banned for reasons such as unsupported operating system or current system environment.

7.1 Patch Management

This requirement is related to IEC 62443-2-4 SP.11.02 BR, SP.11.02 RE (1), SP.11.02

RE (2), SP.11.03 BR, SP.11.04 BR, SP.11.06 BR, SP.11.06 RE (1), and SP.11.06 RE (3). Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.11-2. (SP.11.02 BR).

Create and describe a patch list that covers requirement points (1) to (5) of SP.11.02BR:

(1) The patch must be verified by the service provider. The original factory provides genuine authorized automation solution components security patch items, and all systems ensure that each device patch is updated to the latest version before SAT.

(2) Before applying for the patch project to the asset owner, the equipment provider must test whether the patch scheme can be implemented and verify its reliability. In the automated solution, in order to maintain the reliability and stability of the system operation after the SAT test, it is usually not possible. Unplanned updates, except when equipment vendors discover major vulnerabilities or security-related patches.

(3) If an antivirus software patch needs to be updated, AD/DC will integrate the patch according to the policy.

(4) If applying an approved patch requires or results in a system restart, it must be performed with the approval of the asset owner, usually during system downtime or annual maintenance.

(5) Requests to update the security patch program must be approved by the asset owner through the application, together with the reasons for disapproval or inapplicability.

(6) Applicable but unapproved remediation plans, unapproved items in the automation solution must have a plan with the asset owner to implement a remediation plan when the system can be shut down or decommissioned.

Depending on the service and the same or policy, the equipment provider provides the asset owner with a list of patch plans within an agreed time frame to review security patches for planning.

Note: This process often requires cooperation with the supplier of the control system or component.

2 Description relates to 7.4.1.11-3. (SP.11.02 RE (1)).

(1) Select and use industry and security community-accepted communication interfaces for reporting patch lists.

(2) Use this communication interface to report the patch list to the asset owner, meeting requirements (1)-(3) of SP.11.02 RE (1):

- Approved security patches for automation solution software for which the service provider is responsible (for example, control system and component software, operating system software and 3rd party software applications, or Active Directory supported by the asset owner for antivirus

software renew);

- Applicable security patches have been approved for use in automated solutions. If the patch is updated by the system provider, the security of the tools should be ensured (such as: portable devices, storage devices (USB), etc. need to be scanned and verified. Knowing malicious viruses can only be carried out).
- The version number of the software to which the approved patch applies. This list is provided to asset owners for patch verification and review after a patch is released by the manufacturer and must be subject to a service contract.

(3) Make this list available within an agreed time frame (either specific by contract or by default policy).

3 Description relates to 7.4.1.11-3. (2). (SP.11.02 RE (2)).

(1) Create mitigation plans for applicable patches that were not approved by the Asset Owner Obtain Asset Owner’s approval for their implementation

(2) Implement the agreed mitigation plan

(3) Develop and implement mitigation plans for applicable patches not approved by the asset owner, including:

- Review the severity of the vulnerability that the patch addresses.
- Determine the specific asset(s) impacted by the patch and evaluate whether the system is operating normally;
- Create the mitigation plan base on the above results.
- Obtain approval from the asset owner for its implementation; and
- Implement the agreed mitigation plan.

4 Description relates to 7.4.1.11-4. (SP.11.03 BR).

(1) Ensure that Asset Owner obtains security patches in a reliable way, by selecting one of the two points of the requirement or both

(2) Obtain approval from the Asset Owner and patch manufacturer with license agreement:

- patches to be obtained by the Asset Owner directly from the patch's manufacturer; and/or
- redistribution of patches by the Server Provider only if approved by the Asset Owner and permitted by the patch manufacturer.

5 Description relates to 7.4.1.11-5. (SP.11.04 BR).

(1) The asset portable media and/or patch management server in the automation solution needs to be updated using a licensed storage device (eg, USB).

(2) Ensure that the patch management server satisfies the following requirements:

- When using a patch management server, please refer to the maintenance

manual to explain how to use the server to install patches and the process.

- For manual patching using portable media, a document explaining how to install the patch from the media should be provided.

6 Description relates to 7.4.1.11-6. (SP.11.05 BR).
Provide the “PATCH APPLICATION FORM” to enhance the documented process to obtain approval from the asset owner for patch installation, as the following Table.

Name	Information or Note
Title	
Asset ID	
Date	Date to patch
Type of Patch	Software, firmware
Patch Name /Description	
Patch ID and/or version	
Patch Release Date	
Vulnerability/CVE	If applicable
Affected Asse	List the specific systems, servers, applications, or assets affected
Severity of Vulnerability	Brief description of the risk or vulnerability addressed by this patch, including potential consequences of not applying it
Validation for the Patch	Provide the test result if applicable
Backup Status	Confirm that a complete backup of the system has been made and is available
Rollback Plan	Provide a brief description of the rollback procedure in case of failure
Executor	Company: Name: (Sign)
Approval	[ ] Yes / [ ] No Name: (Sign)
Comments/Concerns	insert any comments or concerns from the asset owner, if any

7 Description relates to 7.4.1.11-7. (SP.11.06 BR).

(1) Request requirements from asset owners about which patches should be installed by service providers.

(2) Ensure that relevant security patches are installed at the time specified by the asset owner.

8 Description relates to 7.4.1.11-7. (1). (SP.11.06 RE (1)).

(1) Ensure that patch installation does not degrade the hardening level of the automation solution.

(2) A documented process to ensure that the installation of patches does not degrade the hardening level:

a Documentation of expertise and completed training in hardening.

b Relevant checklists/templates such as:

- Patch installation temporary deactivation enhancement measures list.
- Temporarily apply configuration changes during patch installation.
- Verification/confirmation procedure of primary hardening level after patch installation

(3) The related checklist for security hardening level after patch installation is shown as follow. The follow table could be used to checklist for Temporary Deactivated Hardening Measures.

No.	Hardening Measure	Status Before Patch	Action Taken During Patch	Status After Patch	Responsible Party	Comments
1	Disable Firewall Rules	Active / Disabled	Disabled / Re-enabled	Active / Disabled		
2	Disable Intrusion Detection System	Active / Disabled	Disabled / Re-enabled	Active / Disabled		
3	Disable Antivirus / Malware Scanners	Active / Disabled	Disabled / Re-enabled	Active / Disabled		
4	Disable Logging Services	Active / Disabled	Disabled / Re-enabled	Active / Disabled		

(4) The related checklist for security hardening level after patch installation is shown as follow. The follow table could be used to checklist for Temporarily Applied Configuration Changes During Patch Installation.

No.	Configuration Change	Before Patch Installation	Temporary Change During Patch	After Patch Installation	Responsible Party	Comments
1	Port Number Change	[Port Number]	[Port Number]	[Port Number]		
2	Configuration File Change	[Original Value]	[New Value]	Update Value		
3	User Permissions Change	[Original Permission]	[New Permission]	[Original Permission]		
4	Network Interface Change	[Original Setting]	[New Setting]	[Original Setting]		

(5) The related checklist for security hardening level after patch installation is shown as follow. The follows are as an example of verification / validation step of former hardening level after patch installation.

Verification Step	Action to Perform	Responsible Party	Comments
1. Verify Firewall Rules	Check that all necessary firewall rules are active and correctly configured.		
2. Verify IDS/IPS	Confirm that the IDS/IPS system is active and properly monitoring for potential threats.		
3. Check Antivirus/Malware Scanners	Ensure that antivirus/malware scanning is operational and updated to the latest signature set		
4. Check System Logs	Ensure logging services (e.g., syslog, auditing) are enabled and logs are being generated.		

9 Description relates to 7.4.1.11-7. (2). (SP.11.06 RE (2)).

(1) Ensuring the integrity and authenticity of patches delivered over the network:

(2) Documentation of controls which are used to ensure authenticity and integrity of patches and their source;

(3) Documentation describing mechanisms that ensure that devices do not install patches that have been modified from their original version (as produced by the patch manufacturer).

10 Description relates to 7.4.1.11-7. (3). (SP.11.06 RE (3)).

Provide a process for verifying patch files after installation (eg, dumping patches from a patched device or checksums computed from a device). The process/technique of ensuring attacker access to the network is not possible during patch installation.

7.2 Validation and Testing

This requirement is related to IEC 62443-2-4 SP.11.01 BR and SP.11.01 RE (1).

1 Description relates to 7.4.1.11-2. (SP.11.01 BR).

Document its evaluation and approval of security patches that are applicable to the Automation Solution.

Note: This process often requires cooperation with the supplier of the control system or component.

(1) Documented process that ensures evaluation and approval of security patches for use in the Automation Solution;

(2) Documentation that describes how security patches are evaluated and approved for use in the Automation Solution; and

(3) Related checklists/templates for evaluation and approval of patches.

2 Description relates to 7.4.1.11-2. (1) (SP.11.01 RE (1)).

Make sure that security patch management process is reviewed and updated according to changing risks:

(1) Documented process for reviewing and updating the process used to evaluate and approve security patches for use in the Automation Solution according to changing risks; and

(2) Related checklists/templates.

8.0 Backup and Restore

List of subsystems or assets to which this security measures/countermeasures apply.
Backup and restore is a kind of periodic data replication, which can achieve the backup function through mirroring, copying and other methods with the Cohesity agent. Data recovery can be achieved in the event of a power outage, cyber-attack or emergency. Achieve its restore time objective (RTO) and restore point objective (RPO).

8.1 Backup Schedules Configuration

This requirement is related to IEC 62443-2-4 SP.12.01 BR, SP.12.02 BR, SP.12.03 BR, SP.12.04 BR, SP.12.05 BR, SP.12.06 BR, SP.12.07 BR, SP.12.08 BR, and SP.12.09 BR. Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.12.-1. (SP.12.01 BR).
Provide instructions for backing up the Automation Solution (or its components) covering the points 1)-4) of the requirement:

(1) Instructions on how to make a full backup of the Automation Solution, and partial backups if applicable, using at least one of the following methods:
   - a proprietary backup architecture on removable media;
   - b single system backup architecture on removable media;
   - c distributed back-up architecture in which each backup system backs up a subset of the Server Provider's Automation Solutions at the Asset Owner's site; or
   - d centralized back-up architecture using one backup system for all of the Server Provider's Automation Solutions at the Asset Owner's site.

(2) Provisions to back-up the following types of data:
   - a operation system files and cryptographic data (e.g., keying material);
   - b applications (including middleware, such as tunnelling software);
   - c configuration data, database files;
   - d log files, electronic log book;
   - e unconventional file types including, but not limited to network equipment settings, control system controller settings (tuning parameters, set points, alarm levels);
   - f field instrumentation parameters;
   - g directory information; and
   - h other files identified by the Server Provider that are required to create a complete backup of the Automation Solution.

(3) Recommendations for offsite storage of backup media; and

(4) Provisions to ensure changes to the Automation Solution that could affect the integrity of a backup are not made while a backup is in progress.

Notice that partial restore examples for a description of the backup automation solution include operating system, application software, databases, and configuration files.

The following is an example as reference to meet the requirement of SP.12.01 BR.

(1) Instructions on how to perform a full and partial backup (if applicable) of the automated solution using at least one of the following methods:

Backup project	Backup Solution	RPO Target
Windows system image	Use the Windows Backup and Restore automatic schedule to place backup targets at Cohesity locations.	Every 6 Month
Configuration file	Use the Windows Backup and Restore automatic schedule to place backup targets at Cohesity locations.	Every 6 Month
Palo Alto Log	Use the Windows Backup and Restore automatic schedule to place backup targets at Cohesity locations.	According to policy

(2) Provisions for backing up the following types of data:
   a Operating system files and encrypted data: managed by XXXXX AD/DC integration
   b Application: Full backup of engineering server asset operating system to Cohesity.
   c Configuration data and database files: All OT equipment configuration files are backed up to the engineering server
   d Log files, electronic logs: According to the policy, they are forwarded to the Server through the Splunk agent and backed up by the asset owner.
   e Other files required to create a full backup of the automated solution as determined by the service provider.

(3) All backup information is kept in the Cohesity agent;

(4) Ensure that no changes are made during the backup process to automated solutions that could affect the integrity of the backup. Includes operating system, application software, database, and configuration files.

2 Description relates to 7.4.1.12.-2. (SP.12.02 BR).

Provide instructions for restoring the Automation Solution (or its components) from a backup, including any conditions that could interfere with the success of restore operations:

(1) Documented process to create/maintain backup/restore instructions to the Asset Owner;

(2) Backup/restore user manuals/instructions ensuring that all Automation Solution components are included in the instructions for the restoration process; and

(3) Documentation of identification of conditions that may interfere with successful restoration and activities to prevent such interference, or a statement and clarification that no such conditions exist.

(4) Provide instructions for restoring the automated solution (or its components)

from the backup, including any conditions that may affect the success of the restore operation.

(5) Identification documentation of conditions that may interfere with successful recovery and activities to prevent such interference, or a statement and clarification that such conditions do not exist.

(6) A written process for creating/maintaining backup/restore instructions to asset owners.

Step 1.	Open Acronis with a browser.
Step 2	Insert license key.
Step 3	Select PLANS > Select Protection and then Create Plan.
Step 4	Enable Backup, and then “Entire Machine. And then “Where to back up”. Select “Network folder” Enter the specified address location.
Step 5	All other options should be disabled.
Step 6	Go to Devices and apply the protection plan.

(7) Backup/restore user manuals/instructions, ensuring that all automation solution components are included in the instructions for the recovery process.

Step 1.	Insert the USB key and use the Rufus program file selection mode "Write ISO Image mode" to write the backup ISO file to the USB.
Step 2.	Perform the recovery procedure, select "Recovery" > "Reboot Now" to enter the BIOS.
Step 3.	Select "Trouble Shoot" > "UEFI Firmware Setting", then "press" Restart. Select "Standard Mode" > select USB boot > select "Save and Exit".
Step 4.	After the USB boots, boot the server from the Acronis recovery media. "Configure Network", Make sure the IP address is set to the server's original IP.
Step 5.	Go to "Manage this machine locally". > Click Recover > Click Select Data... > Network Folders in the What to Recover section.
Step 6.	In the "Path" section, type the path of the SMB share where the backup is stored, remember to start with "smb:" Type your credentials to access the SMB share.
Step 7.	After selecting the backup content, you want to restore from, the restore task begins
Step 8.	Select "Exit" from the Acronis menu. Select "Reboot" on the next page and complete the recovery.

(8) Ensure that the power supply is stable when all assets are backed up and restored, and the network connection is maintained to avoid backup or restore failures.

3 Description relates to 7.4.1.12.-3. (SP.12.03 BR).

Provide instructions for securely handling removable backup media e.g., off-site storage of the media, data at rest or data streamed:

(1) Documented process to provide documentation to the Asset Owner to handle removable backup media securely.

(2) Backup/restore user manuals/instructions containing information about securing removable backup media; and

(3) Description of best practices for handling removable backup media.

This section describes the relevant procedures for removable backup media and does not apply to the backup and restore instructions in the Automation Solution.

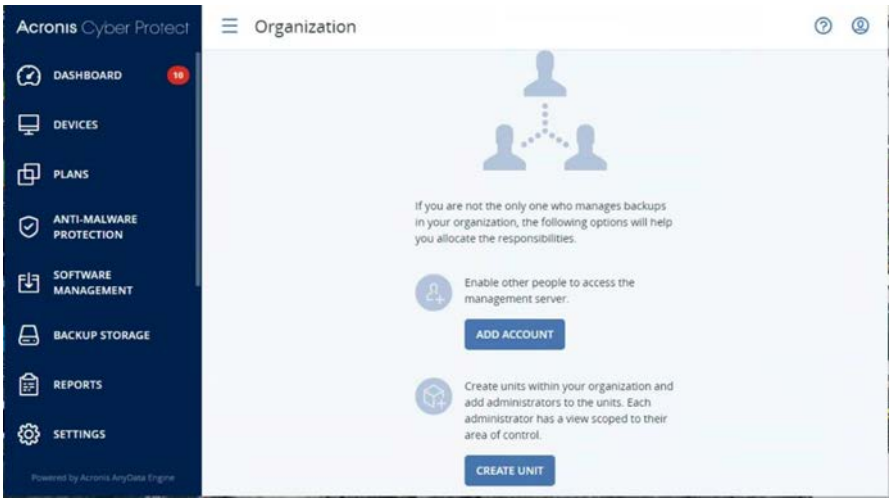
4 Description relates to 7.4.1.12.-4. (SP.12.04 BR).

Provide instructions for verifying that a backup was successful, e.g. backup integrity verification; and ensuring that all the components from the inventory register are included.

(1) Backup verification.

a Start Windows, and log in as one of the system administrators. Then start the Acronis manager by double clicking on the link at the desktop.

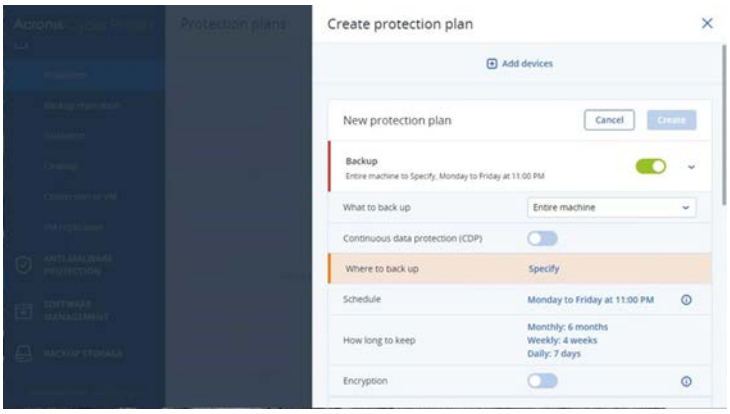
b A bowser window will open and then sign in as the current Window user.



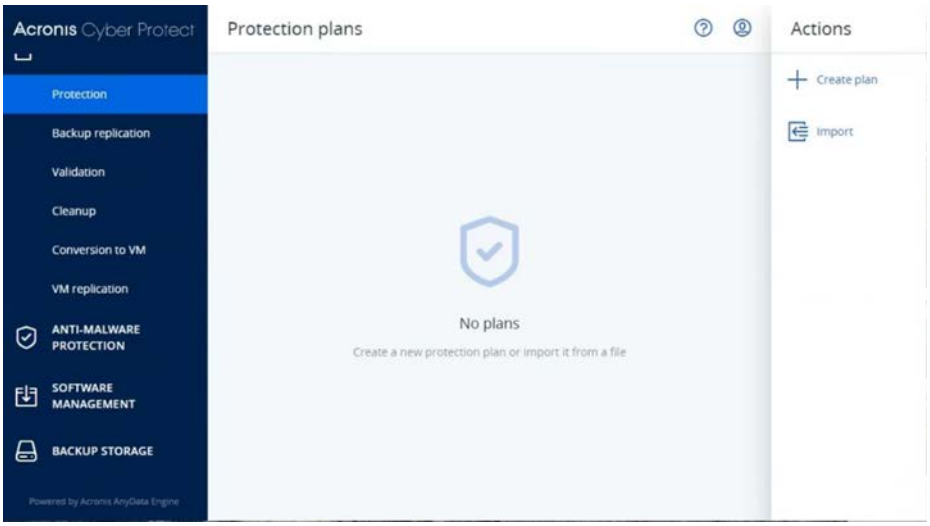
c Select PLANS

d Select Protection and then Create Plan.

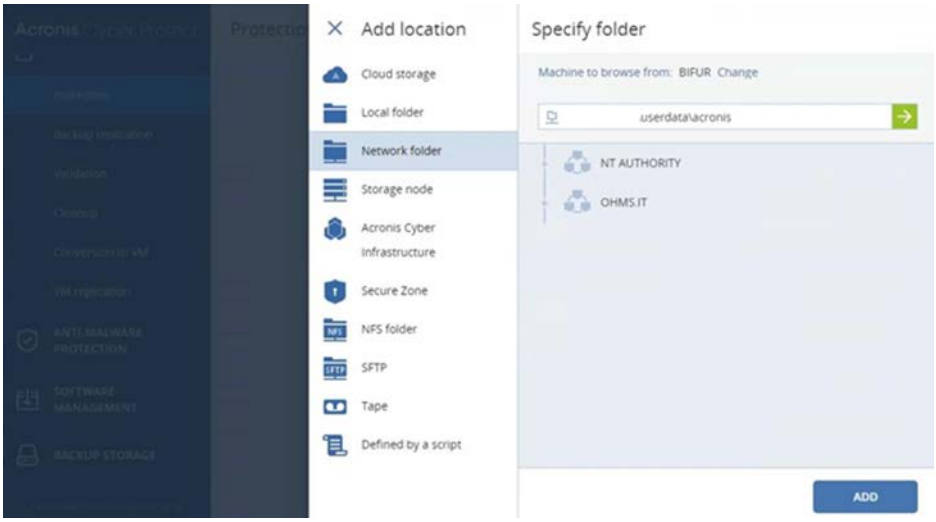
e Enable Backup, and then “Entire Machine.



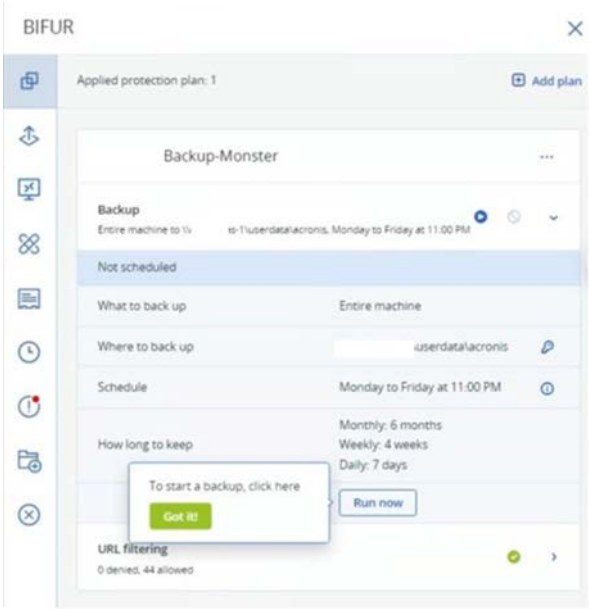
f And then “Where to back up”



g Select “Network folder” Enter the specified address location.



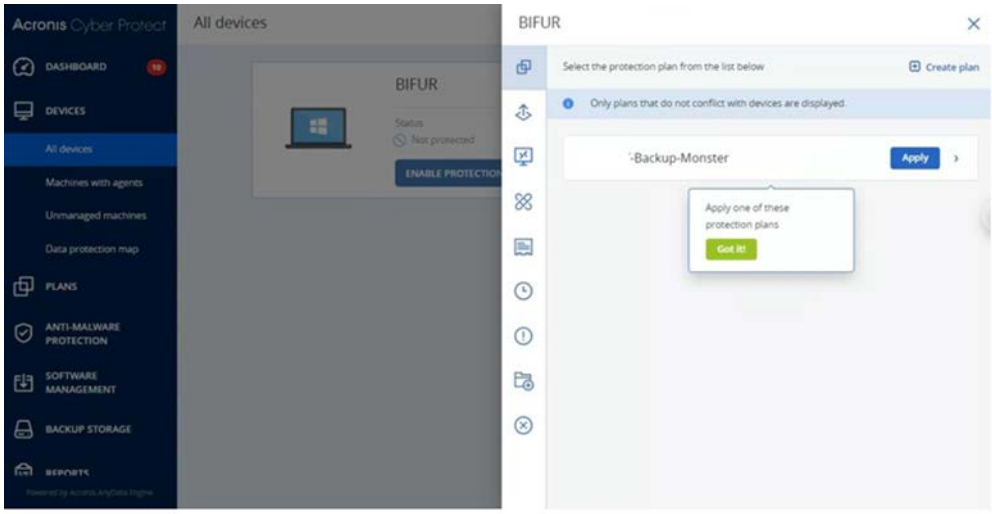
h All other options should be disabled.



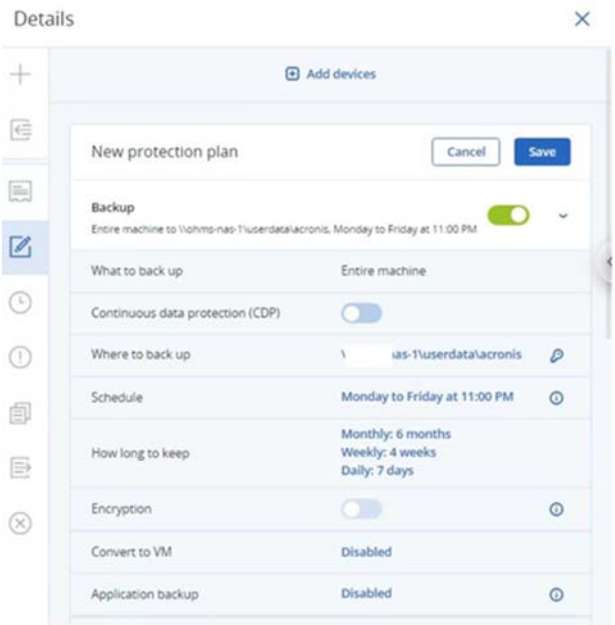
i And press SAVE

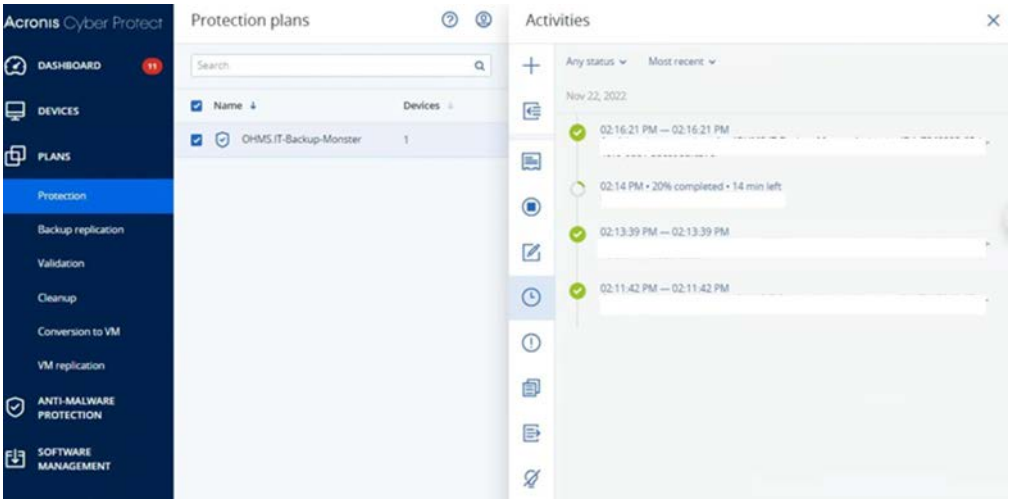
j The protection plan can then be found in the PROTECTION.

k Go to Devices and apply the protection plan.



l And then run the backup for the first time.

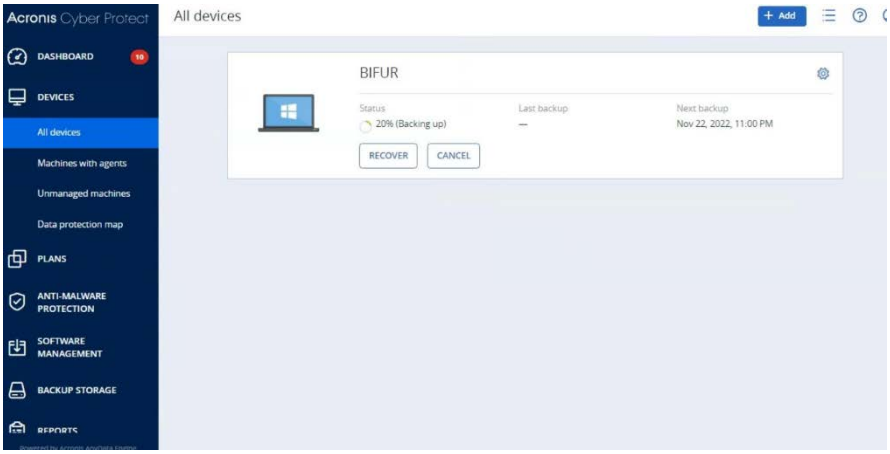




m Clicking on activities indicate that Backup is started.

n You can check the overall progress by selecting the device and make sure that the progress is complete.

o Make sure to include all components in the inventory register that are suitable for backup.



5 Description relates to 7.4.1.12.-5. (SP.12.05 BR).

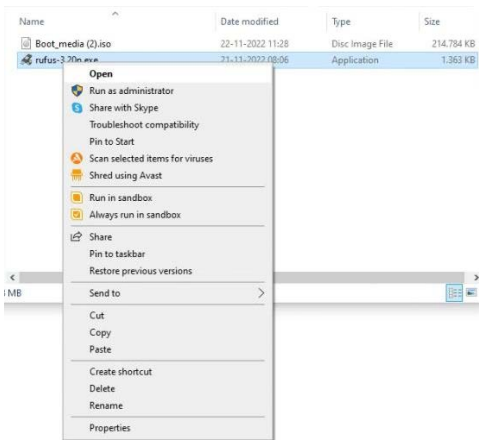
Verify its ability to:

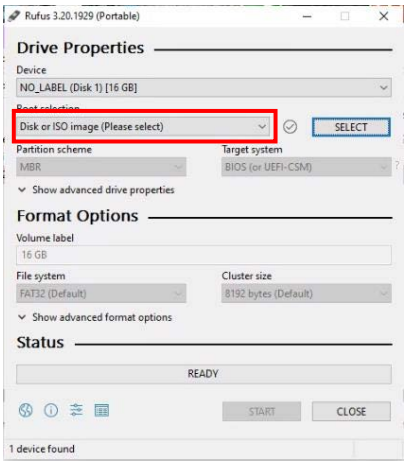
(1) Perform a full backup;

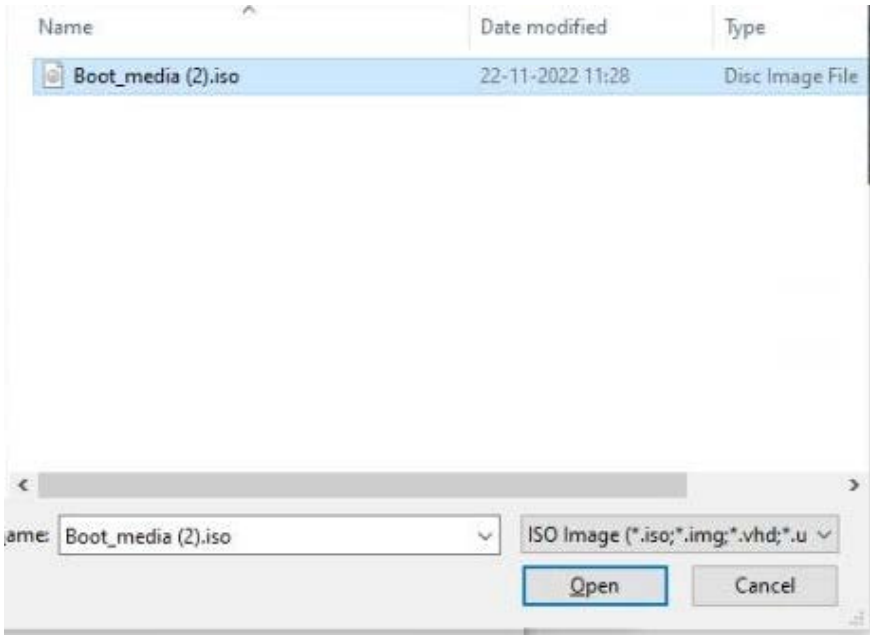
(2) Perform recovery based on this backup and get the full functionality of the automated solution

Test cases, as follows, are provided to perform a full backup, and a restore based on that backup and obtain the full functionality of the automated solution.

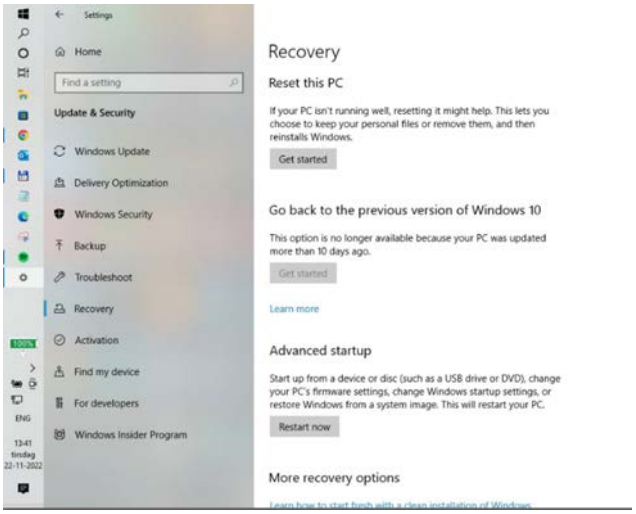
(1) Insert the USB key and use the Rufus program file selection mode "Write ISO Image mode" to write the backup ISO file to the USB.



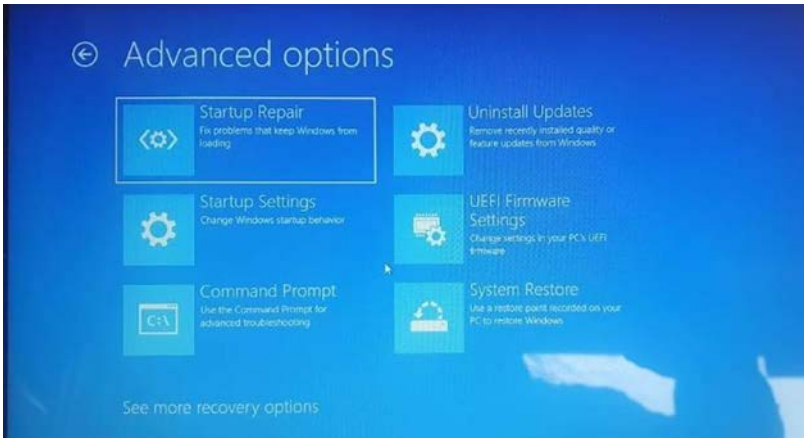


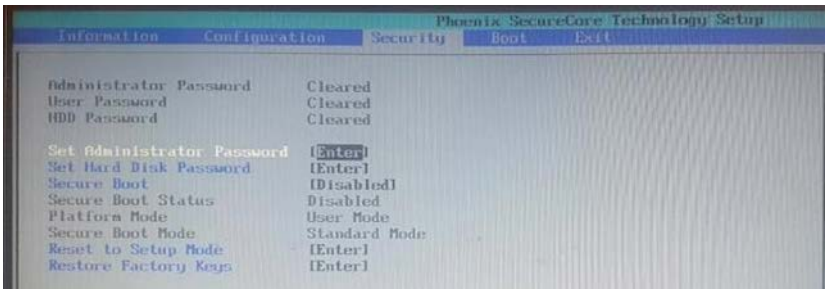


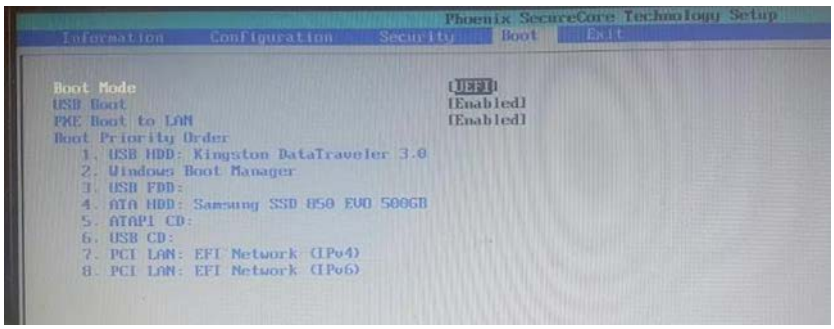
(2) Perform the recovery procedure, select "Recovery" > "Reboot Now" to enter the BIOS.



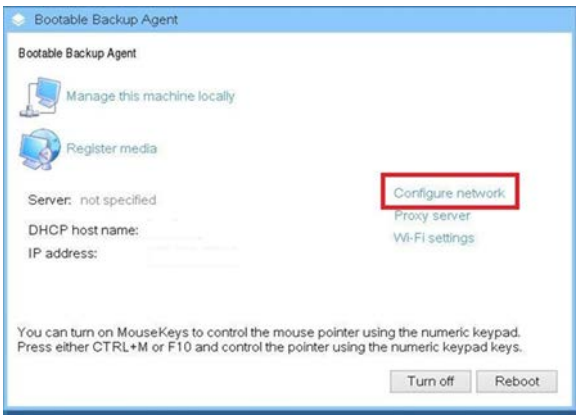
(3) Select "Trouble Shoot" > "UEFI Firmware Setting", then "press" Restart. Select "Standard Mode" > select USB boot > select "Save and Exit".

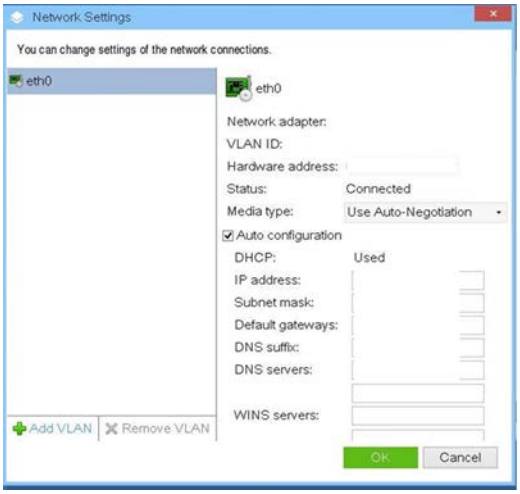




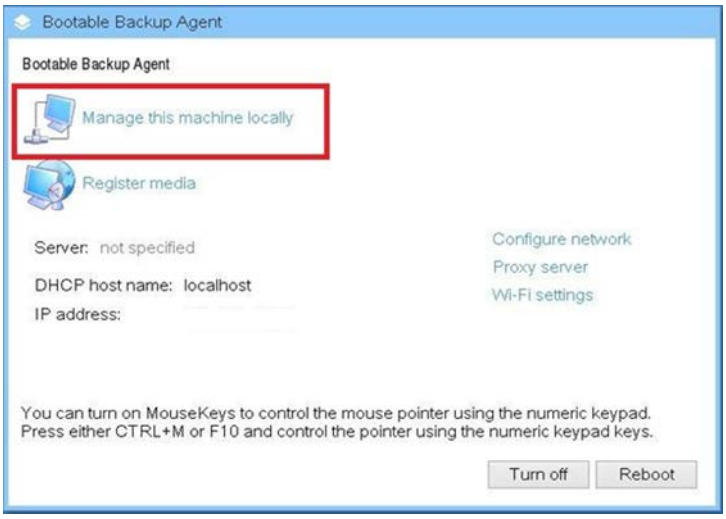


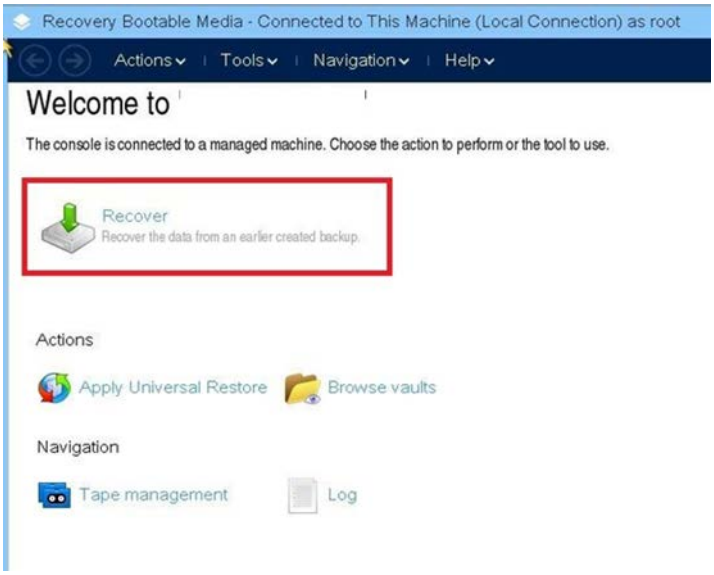
(4) After the USB boots, boot the server from the Acronis recovery media. "Configure Network", Make sure the IP address is set to the server's original IP.

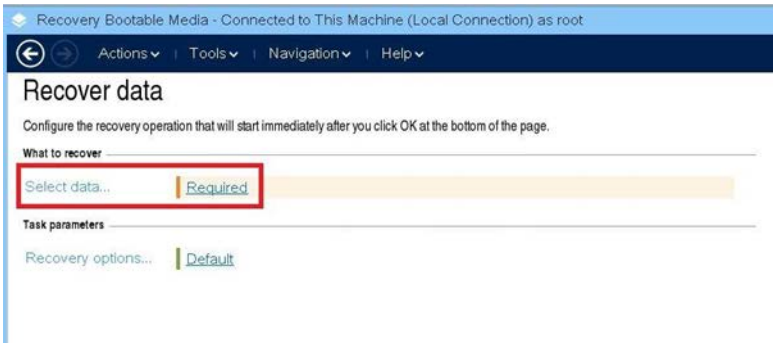




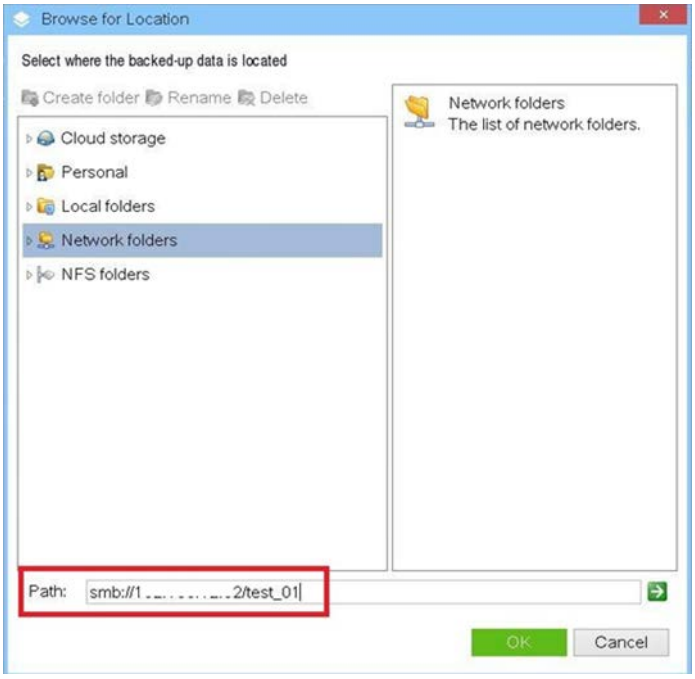
(5) Go to "Manage this machine locally". > Click Recover > Click Select Data... > Network Folders in the What to Recover section.



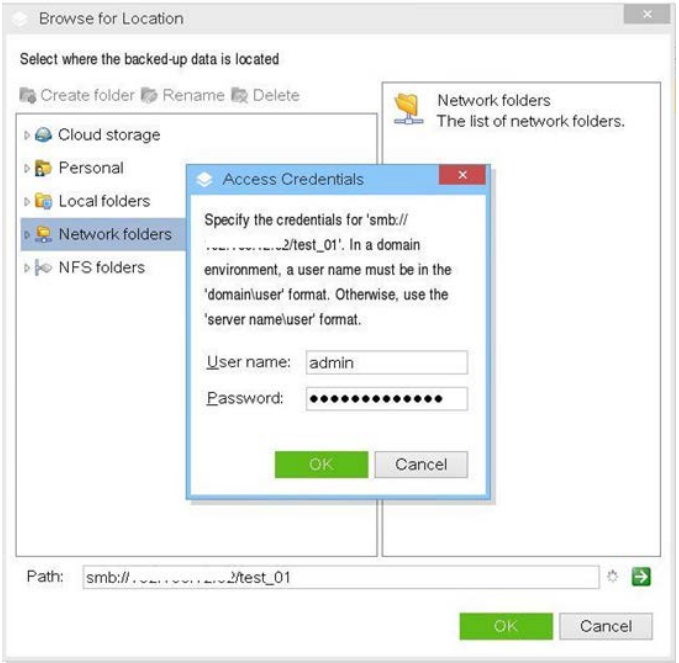




(6) In the "Path" section, type the path of the SMB share where the backup is stored, remember to start with "smb:"

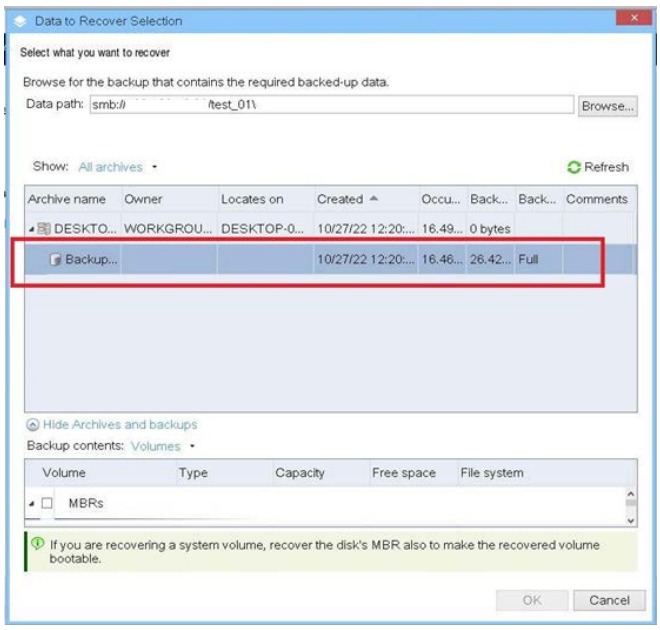


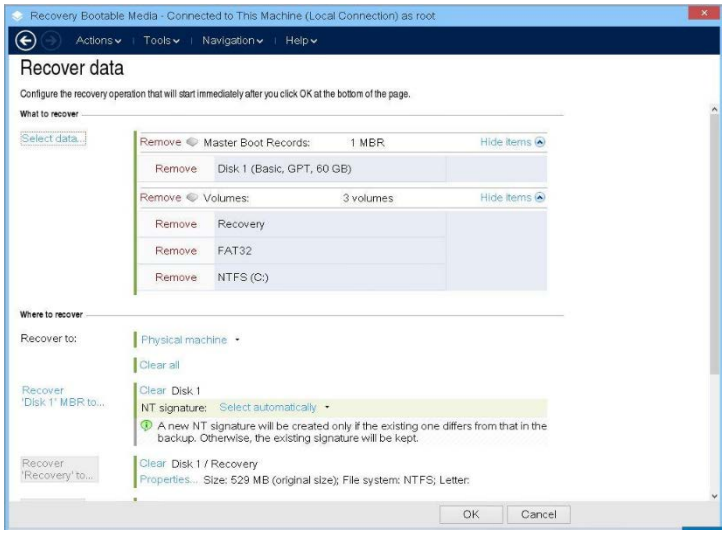
(7) Type your credentials to access the SMB share.

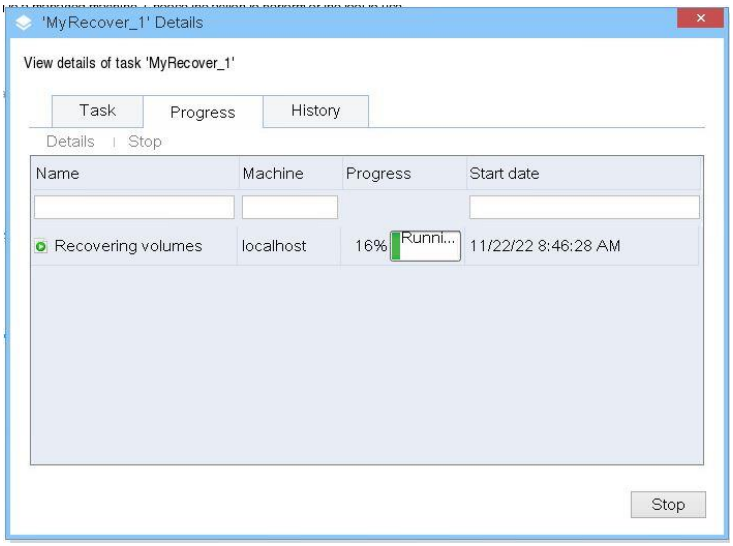


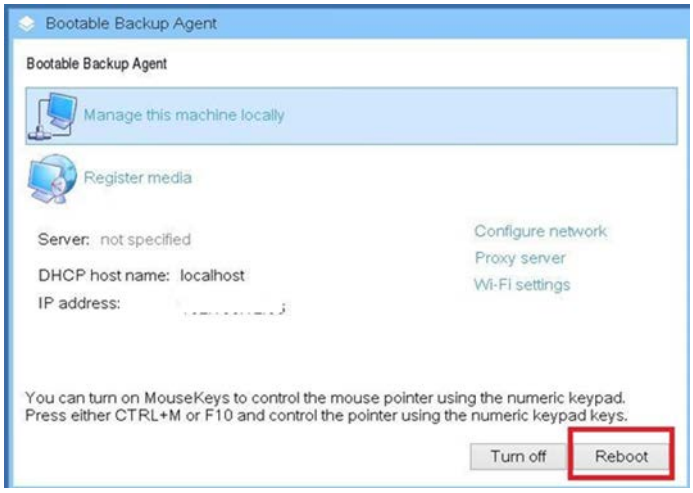
(8) After selecting the backup content, you want to restore from, the restore task begins

Select "Exit" from the Acronis menu. Select "Reboot" on the next page and complete the recover




Recovery Bootable Media - Connected to This Machine (Local Connection) as root
Actions
Tools
Navigation
Help
Recover data
Configure the recovery operation that will start immediately after you click OK at the bottom of the page.
What to recover
Select data...
Remove
Master Boot Records:
1 MBR
Hide items
Disk 1 (Basic, GPT, 60 GB)
Volumes:
3 volumes
Recovery
FAT32
NTFS (C:)
Where to recover
Recover to:
Physical machine
Clear all
Recover 'Disk 1' MBR to...
Clear Disk 1
NT signature:
Select automatically
A new NT signature will be created only if the existing one differs from that in the backup. Otherwise, the existing signature will be kept.
Recover 'Recovery' to...
Clear Disk 1 / Recovery
Properties... Size: 529 MB (original size); File system: NTFS; Letter:
OK
Cancel


'MyRecover_1' Details
View details of task 'MyRecover_1'
Task
Progress
History
Details
Stop
Name
Machine
Progress
Start date
Recovering volumes
localhost
16%
Runni...
11/22/22 8:46:28 AM
Stop


Bootable Backup Agent
Bootable Backup Agent
Manage this machine locally
Register media
Server: not specified
DHCP host name: localhost
IP address:
Configure network
Proxy server
Wi-Fi settings
You can turn on MouseKeys to control the mouse pointer using the numeric keypad.
Press either CTRL+M or F10 and control the pointer using the numeric keypad keys.
Turn off
Reboot

6 Description relates to 7.4.1.12.-6. (SP.12.06 BR).
Ensure that its backup and restore operations are performed in accordance with the Asset Owner schedules, plan and objectives.

7 Description relates to 7.4.1.12.-7. (SP.12.07 BR).
Identify from requirement SP.12.06 BR what is considered normal operation and is relevant to recovery objectives. To ensure that backup operations do not adversely affect normal operations.

8 Description relates to 7.4.1.12.-8. (SP.12.08 BR).
(1) Backup and restoration need to be done in the record and indicate that the owner has completed the backup record.
(2) This part of the event automatically transmits an event log attesting to the completion of the backup or restore procedure.
(3) Provide instructions for configuring backup/restore operations to be recorded/ logged in the audit log.
(4) Provide a description of how these audit logs are maintained.

9 Description relates to 7.4.1.12.-9. (SP.12.09 BR).
Establish and recommend a disaster recovery plan covering at least points 1)-3) of the requirement SP.12.09 for the Automation Solution:
(1) Provide the impact of various disaster scenarios leading to system anomalies on the automation solution.
- For server example, the temperature in the station and the automatic control function of the exhaust system cannot be detected normally.

(2) Step-by-step instructions for restoring, restarting, failing components and integrating them into an automation solution.
(3) Restore the minimum architectural requirements for the entire automation solution

8.2 Recovery Testing Mechanisms

1 Description relates to 7.4.1.12.-5. (SP.12.05 BR).
(1) Provide a process can be performed for the Asset Owner to verify its ability to perform a full backup and perform a restore based on that backup and to get the full functionality of the Automation Solution.
(2) Provide test case to perform a full backup and provide test case to perform a restore based on that backup and to get the full functionality of the Automation Solution. RTO target for the server should be less than 24 hr.

8.3 Device and Network Redundancy Configuration

1 If there are any similar designs, to support:
(1) Failure crossover and failure management;
- Perform backup and/or restore activities in operation; and

- Prevent system interruption from a single accident.
- Please describe its design philosophy, architecture, and mechanisms for successful operation in case of the above situation occurs.
- The network of SuC didn’t include redundancy configuration.

8.4 Emergency Power Supply Configuration

1 Please describe its design philosophy, architecture, and mechanisms for successful operation in case of power outage or utilities shutting down during emergency.
2 Show your Backup, Restore, and Recovery Procedures as references evidence.
3 The SuC use UPS A/B circuit power supply.

9.0 Remote Interactive Access

List of subsystems or assets to which this security measures/countermeasures apply. Please refer to the items given in Section 1.2 to perform applicability screening.

This section explains that through remote interactive access, in view of AD/DC integrated management, assets that communicate through the network are allowed, and the following two conditions must be met at the same time.

1. It is limited to the whitelist in the IP list
2. Have the appropriate account permissions

9.1 Session Logging – Event Management

This requirement is related to IEC 62443-2-4 SP.08.02 BR, SP.08.02 RE (2), SP.08.03 BR, SP.08.03 RE (1), and SP.08.04 BR.

Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.9.-3. (SP.08.02 BR).
   (1) Identify all security-related events
   (2) Write them to audit logs
   (3) Configure their retention capabilities as specified by the Asset Owner

2 Description relates to 7.4.1.9.-3. (2) (SP.08.02 RE (2)).
   Simulate a security event and to write security related data to an audit log according to a scenario selected by an Asset Owner

3 Description relates to 7.4.1.9.-4. (SP.08.03 BR).
   Configure process-related events to be logged and notified to the operator according to the details of the requirement

4 Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).
   (1) Verify that alarms/alerts/events can be reported via secure interfaces supported by the Automation Solution
   (2) Show that these are commonly accepted

5 Description relates to 7.4.1.9.-5. (SP.08.04 BR).
   Verify and document that an automation solution is able to withstand event storms:
   (1) Documented process of conducting tests (e.g., robustness test, stress test) at an automation solution to verify that it withstands event storms;
      - Evaluation concept/procedure for architectural features (including rate-limiting network devices) of an Automation Solution with regard to their capabilities to protect against event storms; and
      - Risk assessment procedure that considers event storms and include proper protection.

9.2 Default Credentials Removed

This requirement is related to IEC 62443-2-4 SP.09.02 BR, SP.09.02 RE (1), and SP.09.02 RE (4) which related to Default Credentials Removed.

Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.3.-2. (SP.09.02 BR).

(1) Create and maintain a unique user account for each Automation Solution user

- Create accounts for AD and DC integration and native emergency recovery accounts for automation solution assets according to RBAC policy and delete other default accounts.

2 Description relates to 7.4.1.3.-2. (1). (SP.09.02 RE (1)).

(1) Generate a list of all user and service accounts and providing instructions to the Asset Owner that describes how to change their passwords

- Generate a list of all user and service accounts, manage it by the asset owner, and target RBAC policies through AD/DC integration, providing the accounts used by the vendor for maintenance.

3 Description relates to 7.4.1.3.-2. (4). (SP.09.02 RE (4)).

(1) Disable the administrator account or protect it from exploitation in other ways.

- The account provided by AD/DC integration should be used for system maintenance and maintenance.
- Show your hardening practice and checklist used and show your hardening results as references evidence in this section if appropriate.
- Show your Account Control List and policy as references evidence.

9.3 Multifactor Authentication

This requirement is related to IEC 62443-2-4 SP.07.04 RE (1), SP.03.07 RE (1) and SP.03.08RE (3) for Remote Access.

Provide a process can be performed for the Asset Owner to make sure that each remote access connection using public communication networks is authenticated and encrypted:

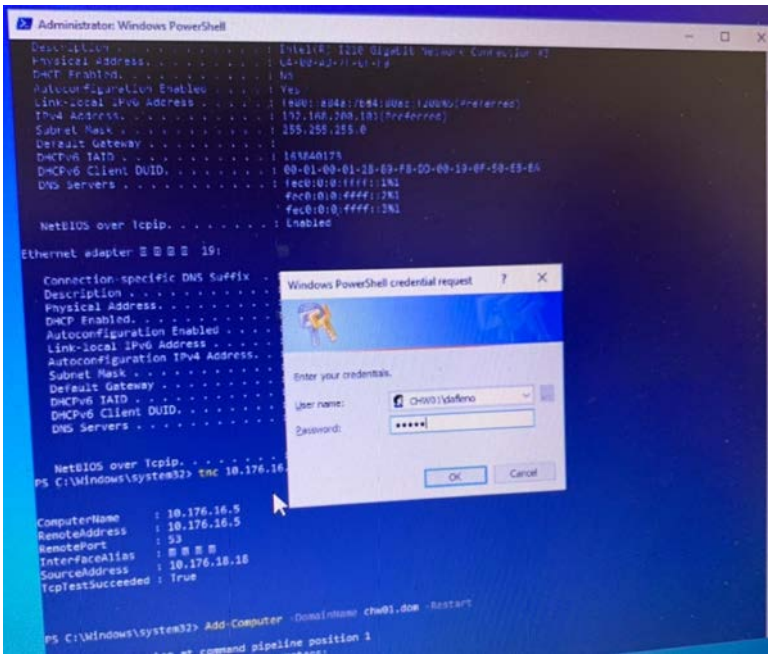
1 Description relates to 7.4.1.8.-5. (SP.07.04 RE (1)) for Remote Access.

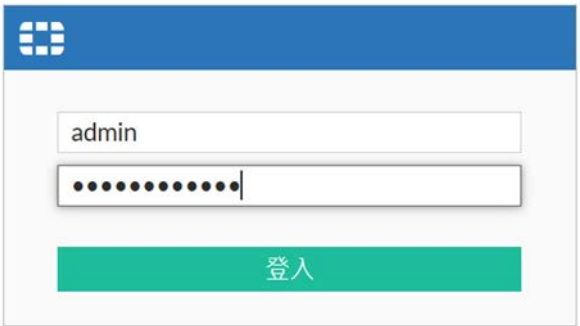
All access to the OT environment is provided by asset owners. Make sure that every remote access connection using the public communication network is authenticated and encrypted:

(1) Ensure that remote access connections using public communication networks are authenticated and encrypted.

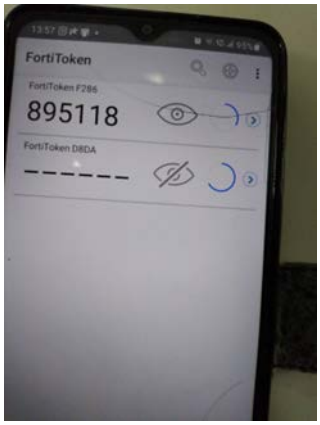
2 Description relates to 7.4.1.2. 8.(3) (SP.03.08RE(3)) for Remote Access.

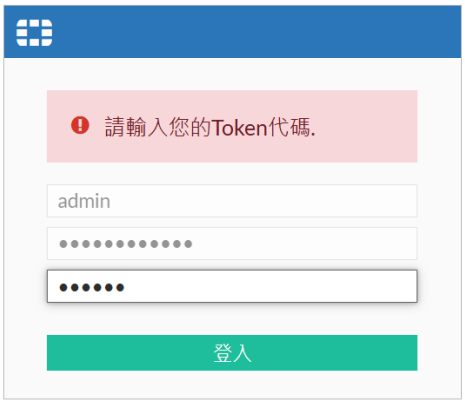
(1) A mutual authentication was used for the administration of communication device. For a firewall (Fertigate), it can use web connection to the firewall for configurating the setting with admin account.



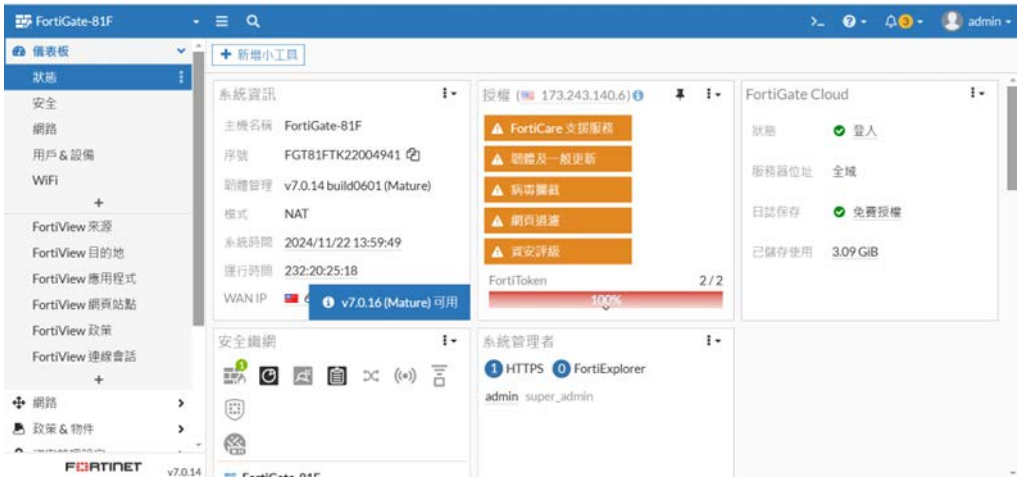


(2) It would request the Token ID that need to be get from another administrator human user's device (e.g. Mobile Phone),





(3) After these 2 factors authentication information both are correct, then can success to login to the network device to operate and maintain the network functions.



10.0 Network Security

List of subsystems or assets to which this security measures/countermeasures apply. Please refer to the items given in Section 1.2 to perform applicability screening.
Building cybersecurity systems for automation solutions Vendors implement security plans in accordance with policies.

10.1 Network Segmentation

This requirement is related to IEC 62443-2-4 SP.03.02 RE (1) for Network Security.
Provide a process can be performed for the Asset Owner to identify and document the network segmentation architecture for the Solution and to identify interfaces as trusted or untrusted e.g., by risk assessments.

1 Description relates to 7.3.1.1-4. (1). (SP.03.02 RE (1)) for Network Security.
Based on the risk assessment policy, the system classifies each system asset into different levels of safety criticality and whitelists the equipment through the network equipment. The interface uses the segmented structure of the VLAN network. When this network enters the substation, the Layer 3 router performs NAT forwarding to achieve network security design.

10.2 Zoning and Conduits

This requirement is related to IEC 62443-2-4 SP.03.02 RE (2), SP.05.06BR and SP.05.08BR for Network Security.

Provide a process can be performed for the Asset Owner to:

1 Conduct risk assessment to verify that identified untrusted network interfaces have adequate protection:
   (1) Document the protection mechanisms and ensure their effectiveness; and
   (2) Ensure protection related to 1) to 5) of the requirement as a minimum:
      - External interfaces.
      - Level 2/Level 3 interfaces (Depending on the Automation Solution, Level 2/Level 3 interfaces may be “External” interface.);
      - Interfaces between the BPCS and the SIS;
      - Interfaces connecting wired and wireless BPCS networks; and
      - Interfaces connecting the BPCS to data warehouses (e.g., enterprise historians).

Notice that the term "Level" in point 2) of the requirement refers to the position in the Purdue Reference Model as standardized by ISA 95 and IEC 62264-1 (see clause 5.3).

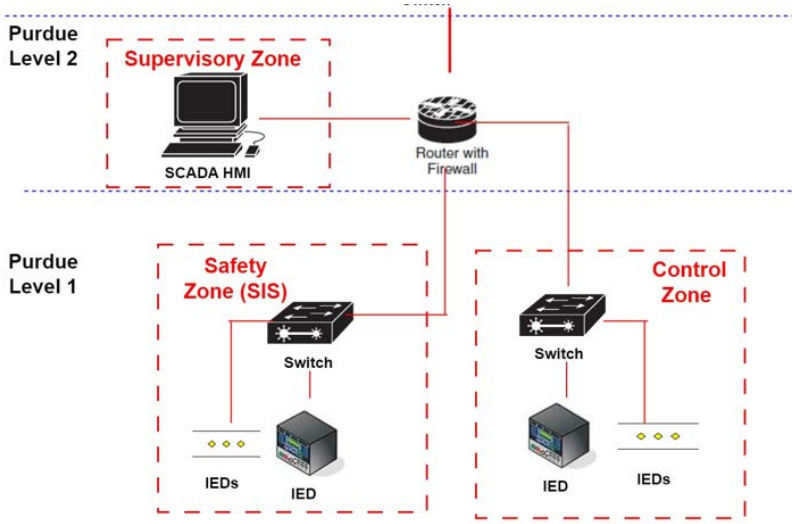
2 Description relates to 7.3.1.1-4. (2). (SP.03.02 RE (2)) for Network Security.
   (1) Conduct a risk assessment to verify identified untrusted network interfaces and associated protections.
   (2) Document protection mechanisms and ensure their effectiveness.

(3) Ensure the protections associated with required in SP.03.02 RE(2) as a minimum:

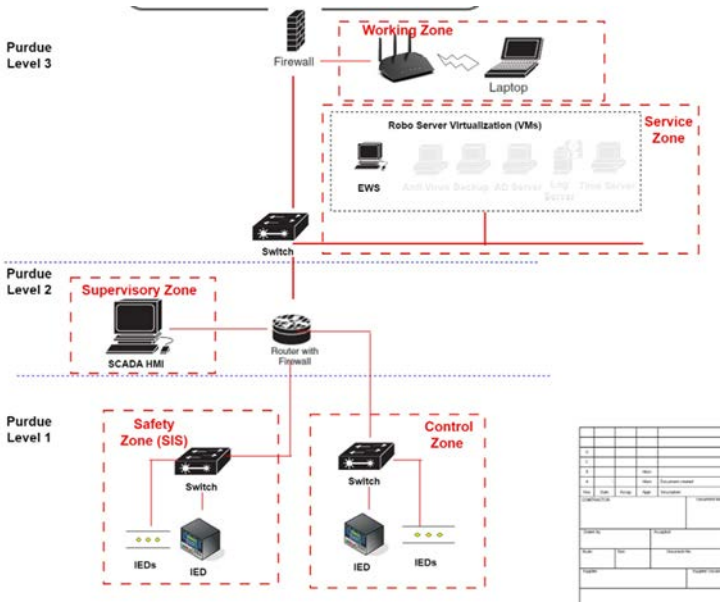
- External interface.
- Level 2/Level 3 interfaces.
- Interface between BPCS and SIS.
- Interface to connect wired and wireless BPCS network.
- The interface connecting BPCS to the data warehouse.

3 Description relates to 7.3.1.7-6. (SP.05.06BR) for SIS Network Security.

A Router with Firewall function should be setup to control the connection between SIS zone, Control zone, Supervisory zone and Service zone. The limitation access rules should be whitelists set and controlled by this Router between SIS zone to Supervisory zone and Control zone.



4 Description relates to 7.3.1.7-8. (SP.05.08BR) for SIS Network Security.
A Firewall should be setup between Working zone and Service zone to control the connection, and A Router with Firewall function should be setup to control the connection between SIS zone, Control zone, Supervisory zone and Service zone. The limitation access rules should be set that the connection between SIS zone Service zone is denied all



10.3 Documentation and Schematics

This requirement is related to IEC 62443-2-4 SP.06.01 BR and SP.06.06.01 RE (1).
Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.4-7. (1) & (2) (SP.06.01 BR).
Generate, deliver, and maintain drawings/descriptions of the solution's network infrastructure, clearly identifying the internal and external interfaces to which devices can connect (e.g., switches, routers, firewalls, network interface cards).

2 Description relates to 7.4.1.4-7. (3). (SP.06.06.01 RE (1)).
Ensure that architecture diagrams, connection diagrams, and configuration (as-built) files always reflect current operating devices and their network connections. The detailed reference document is” Data Flow Diagram”.

10.4 Logging and Auditing Controls – Event Management

This requirement is related to IEC 62443-2-4 SP.08.02 BR, SP.08.03 BR, and SP.08.03 RE (1) which are related to Logging and Auditing Controls for Event Management.
Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.9.-3. (SP.08.02 BR).
   (1) Identify all security-related events
   (2) Write them to audit logs
   (3) Configure their retention capabilities as specified by the Asset Owner

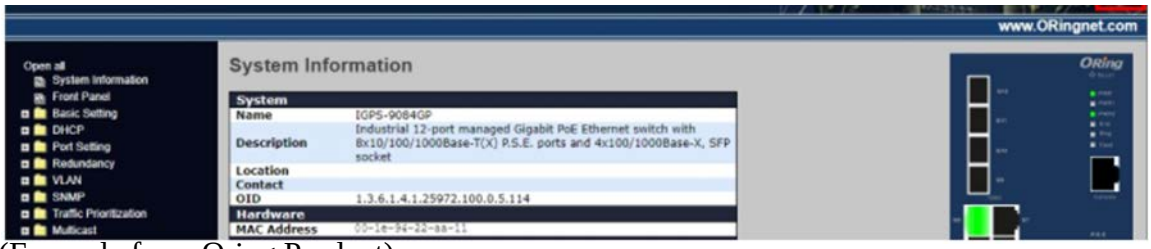
2 Description relates to 7.4.1.9.-4. (SP.08.03 BR).
   Configure process-related events to be logged and notified to the operator according to the details of the requirement

3 Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).
   (1) Verify that alarms/alerts/events can be reported via secure interfaces supported by the Automation Solution
   (2) Show that these are commonly accepted.

10.5 Communication Protection

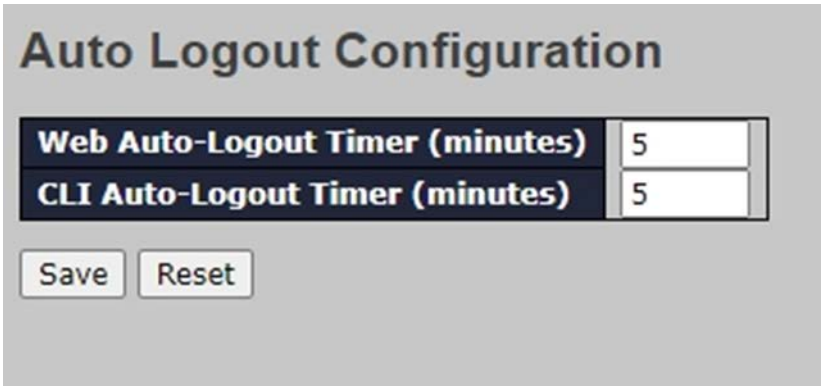
1 Description relates to 7.4.1.2.-5. (SP.03.06 BR, Session locking).
   (Example from Oring Device)
   After the user enters the account and password and presses login, the system randomly generates a session id (4 bytes size) and sends the account and password together with the session id to the web server for authentication. After the verification is successful, the server will create a login info table entry with this session id and mark it as authenticated. Every time an HTTP request is sent, the session ID is included (instead of the account and password information). The server will check the session ID to determine whether the HTTP request is authenticated. If it is not authenticated, the request will be rejected and redirected to the banner webpage. When the user directly closes the browser (completely closing it instead of just closing the tab), the session ID will also disappear, and you will need to log in again to re-establish the connection.

   The system provides a logout button and auto logout when idle for web UI.



(Example from Oring Product)

   When the user manually presses the logout button, the browser will send an http request for logout and clear at the same time, the server will immediately clear the login info table entry of this session id, and then automatically return to the login webpage. After server removed this session id, all http requests with this session id will be considered unauthenticated and return to the banner webpage.



(Example from Oring Product)

When the server does not receive an HTTP request for the session ID for five minutes, it will actively clear the login info table entry for the session ID. If the browser sends an HTTP request for the session ID again, the server will determine it as unauthenticated and automatically return to the banner webpage.

Note that:

(1) *If your browser has JavaScript disabled, you will not be able to log in.
(2) *If your browser disables cookies, you will not be able to log in.
(3) *Browser will be unable to log in if frame is disabled.

2 Description relates to 7.4.1.2.-8(2). (SP.03.08BR (2)).
To show the protection methods for communication for the device.

(Protection method)		SCADA system			Safety Control system	Configuration & Auxiliary management system
Data to protect	Security group AD	SCADA HM	IED (Control)	Ethernet Switch	IED (Protection)	Wireless AP (could be connected to a laptop)
Configuration Web		https, mutual authentication		https, mutual authentication		

11.0 Logging and Auditing – Event Management

List of subsystems or assets to which these security measures/countermeasures apply. Please refer to the items given in Section 1.2 to perform applicability screening.

11.1 Auditable Events Identification

This requirement is related to IEC 62443-2-4 SP.08.02 BR, SP.08.02 RE (2), SP.08.03 BR, SP.08.03 RE (1) and SP.08.04 BR **which related to Auditable Events Identification for Event Management.**

Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.9.-3. (SP.08.02 BR).
   (1) Identify all security-related events
   (2) Write them to audit logs
   (3) Configure their retention capabilities as specified by the Asset Owner

2 Description relates to 7.4.1.9.-3. (2). (SP.08.02 RE (2)).
   (1) Simulate a security event and to write security related data to an audit log according to a scenario selected by an Asset Owner.
   (2) Check the simulated security event whether is created and written in the assigned central log system.

3 Description relates to 7.4.1.9.-4. (SP.08.03 BR).
   Configure process-related events to be logged and notified to the operator according to the details of the requirement

4 Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).
   Verify that alarms/alerts/events can be reported via secure interfaces supported by the Automation Solution
   Show that these are commonly accepted

5 Description relates to 7.4.1.9.-5. (SP.08.04 BR).
   Verify and document that an automation solution is able to withstand event storms:
   (1) Documented process of conducting tests (e.g., robustness test, stress test) at an automation solution to verify that it withstands event storms;
   (2) Evaluation concept/procedure for architectural features (including rate-limiting network devices) of an Automation Solution with regard to their capabilities to protect against event storms; and
   (3) Risk assessment procedure that considers event storms and include proper protection.

11.2 User Logging Configuration

This requirement is related to IEC 62443-2-4 SP.08.02 BR, SP.08.02 RE (2), SP.08.03 BR, SP.08.03 RE (1) and SP.08.04 BR which related to User Logging Configuration for Event Management.

Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.9.-3. (SP.08.02 BR).
   (1) Identify all security-related events
   (2) Write them to audit logs
   (3) Configure their retention capabilities as specified by the Asset Owner

2 Description relates to 7.4.1.9.-3. (2). (SP.08.02 RE (2)).
   (1) Simulate a security event and to write security related data to an audit log according to a scenario selected by an Asset Owner
   (2) Check the simulated security event whether is created and written in the assigned central log system.

3 Description relates to 7.4.1.9.-4. (SP.08.03 BR).
   Configure process-related events to be logged and notified to the operator according to the details of the requirement

4 Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).
   (1) Verify that alarms/alerts/events can be reported via secure interfaces supported by the Automation Solution
   (2) Show that these are commonly accepted

5 Description relates to 7.4.1.9.-5. (SP.08.04 BR).
   Verify and document that an automation solution is able to withstand event storms:
   (1) Documented process of conducting tests (e.g., robustness test, stress test) at an automation solution to verify that it withstands event storms;
   (2) Evaluation concept/procedure for architectural features (including rate-limiting network devices) of an Automation Solution with regard to their capabilities to protect against event storms; and
   (3) Risk assessment procedure that considers event storms and include proper protection.

11.3 Device Logging Configuration

Device Logging Configuration
This requirement is related to IEC 62443-2-4 SP.08.02 BR, SP.08.02 RE (2), SP.08.03 BR, SP.08.03 RE (1) and SP.08.04 BR which related to Device Logging Configuration for Event Management.

Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.9.-3. (SP.08.02 BR).
   (1) Identify all security-related events
   (2) Write them to audit logs
   (3) Configure their retention capabilities as specified by the Asset Owner

2 Description relates to 7.4.1.9.-3. (2). (SP.08.02 RE (2)).
   (1) Simulate a security event and to write security related data to an audit log according to a scenario selected by an Asset Owner
   (2) Check the simulated security event whether is created and written in the assigned central log system.

3 Description relates to 7.4.1.9.-4. (SP.08.03 BR).
   Configure process-related events to be logged and notified to the operator according to the details of the requirement

4 Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).
   (1) Verify that alarms/alerts/events can be reported via secure interfaces supported by the Automation Solution
   (2) Show that these are commonly accepted

5 Description relates to 7.4.1.9.-5. (SP.08.04 BR).
   Verify and document that an automation solution is able to withstand event storms:
   (1) Documented process of conducting tests (e.g., robustness test, stress test) at an automation solution to verify that it withstands event storms;
   (2) Evaluation concept/procedure for architectural features (including rate-limiting network devices) of an Automation Solution with regard to their capabilities to protect against event storms; and
   (3) Risk assessment procedure that considers event storms and include proper protection.

11.4 Network Logging Configuration

This requirement is related to IEC 62443-2-4 SP.08.02 BR, SP.08.02 RE (2), SP.08.03 BR, SP.08.03 RE (1) and SP.08.04 BR **which related to Network Logging Configuration for Event Management.**

Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.9.-3. (SP.08.02 BR).
   (1) Identify all security-related events
   (2) Write them to audit logs
   (3) Configure their retention capabilities as specified by the Asset Owner

2 Description relates to 7.4.1.9.-3. (2). (SP.08.02 RE (2)).
Simulate a security event and to write security related data to an audit log according to a scenario selected by an Asset Owner

3 Description relates to 7.4.1.9.-4. (SP.08.03 BR).
Configure process-related events to be logged and notified to the operator according to the details of the requirement

4 Description relates to 7.4.1.9.-4. (1). (SP.08.03 RE (1)).
(1) Verify that alarms/alerts/events can be reported via secure interfaces supported by the Automation Solution
(2) Show that these are commonly accepted

5 Description relates to 7.4.1.9.-5. (SP.08.04 BR).
Verify and document that an automation solution is able to withstand event storms:
(1) Documented process of conducting tests (e.g., robustness test, stress test) at an automation solution to verify that it withstands event storms;
(2) Evaluation concept/procedure for architectural features (including rate-limiting network devices) of an Automation Solution with regard to their capabilities to protect against event storms; and
(3) Risk assessment procedure that considers event storms and include proper protection.

11.5 Security Tools Logging – Malware Protection

1 Description relates to 7.4.1.9.-3. (1). (SP.08.02 RE (1)) which related to Security Tools Logging for Malware Protection.
Provide a process can be performed for the Asset Owner to document and maintain the anti-malware software status for each component of the Automation Solution according points 1) to 4) of the requirement:
(1) The installation state of malware protection mechanisms or a statement that it is not technically possible to install malware protection mechanisms on the component.
(2) The current configuration settings of the installed malware protection mechanism.
(3) The status of malware definition files approved for installation on the component; and
(4) The use of other mitigating features and functions used to reduce the risk of infection and/or mitigate the effect of infections (e.g., isolating infections, reporting infections).

2 The following interfaces are suggested the asset owners to access security-related data and events:
(1) RESTful APIs: Secure APIs to fetch real-time and historical security event logs, vulnerability reports, and compliance status.
(2) Syslog & SIEM Integration: Forwarding logs via Syslog, CEF, or JSON formats to Security Information and Event Management (SIEM) systems.

(3) Web Dashboard & Portal: A secure web-based UI for real-time visualization of security events, configurations, and compliance reports.

(4) OT-Specific Protocols: Support for industrial security standards such as OPC UA Security, IEC 62443-compliant interfaces.

The choices should be depended on the functionality of asset and implemented system and chosen should be configured based on SuC of implemented system. The choice should be test and/or inspected whether the function is configurated and operated well through simulated a security-related event.

11.6 Threat Detection

This requirement is related to IEC 62443-2-4 SP10.05 BR, SP10.05 RE (1), and SP10.05 RE (2) which related to Threat Detection for Malware Protection.
Provide a process can be performed for the Asset Owner to:

1 Description relates to 7.4.1.10.-5. (SP10.05 BR).
Make sure that components/workstations are free of known malware when integrated into the Automation Solution

2 Description relates to 7.4.1.10.-5. (1). (SP10.05 RE (1)).
Make sure portable media is used only for its intended purpose

3 Description relates to 7.4.1.10.-5. (2). (SP10.05 RE (2)).
Make sure that portable media are free of malware when used in the Automation Solution

11.7 Intrusion Detection and Protection Configuration

This requirement is related to IEC 62443-2-4 SP10.03 BR which related to ntrusion Detection and Protection Configuration or Malware Protection.
Provide a process can be performed for the Asset Owner to verify the correct operation of the anti-malware mechanisms at the component, systems and solution level (e.g. configuration, detection, mitigation, logging/, notifications) to provide protection against known malware.

1 Description relates to 7.4.1.10.-3. (SP10.03 BR) which related to intrusion Detection and Protection Configuration or Malware Protection.

11.8 Monitoring Use Cases

Any Monitoring Use Case related to SuC's Security Event Management should be described in this section, if appropriate.

12.0Safety Instrumented System (SIS)

12.1 Safety Instrumented System (SIS) security (if applicable)

1 Description relates to 7.3.1-8. (SP.05.01 BR).

(1) Provide a process can be performed for the Asset Owner to verify that security architecture reviews and/or security risk assessments of the communications of the SIS used in the Automation Solution have been conducted and addressed.

(2) The service provider should use Document ID02 Table C.5 to verify that Review security architecture and the communications of the SIS used in the SuC are conducted and addressed by through VCSD.13. The Project/System Data Flow Diagram should be reviewed whether contains the updated Network and Data Flow Diagram according to the Project/System Threat and Risk Assessment Report. It should be ensured that security risk assessments of the communications of the SIS used in the Automation Solution have been conducted and addressed in the Project/System Threat and Risk Assessment Report.

(3) Document ID 08 is the Project/System Data Flow Diagram of dummy project and ID 11 is the Project/System Threat and Risk Assessment Report of dummy project.

(4) Document ID08 section 3 presents the updated Network Diagram after ILRA to protect SIS and section 5 presents the defense-in-depth architecture of SuC for dummy project after the DTRA, where Document ID11 is the Threat and Risk Assessment Report for dummy project with two appendixes Document ID11_1 ILRA report of dummy project and Document ID11_2 DTRA report of dummy project.

2 Description relates to 7.4.1.7.-1. (SP.05.02 BR).

(1) Provide a process can be performed for the Asset Owner to configure the Automation Solution to protect safety communications and SIS safety functions from the BPCS or any other Automation Solution communications. The SIS communications critical to safety functions shall not be affected by other communications of the Automation Solution. It should have the physical separation of BPCS communications and the SIS.

(2) Document ID02 Table C.6 (through VCSC.31-01) could be used to review that the SIS communications critical to safety functions shall not be affected by other communications of the Automation Solution, and tt should have the physical separation of BPCS communications and the SIS.

(3) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In the figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to protect safety communications and SIS safety functions from the BPCS or any other Automation Solution communications. Also, it will be better that the firewall in Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(4) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14

could be used to validate the set-up firewall rules could protect safety communications and SIS safety functions from the BPCS or any other Automation Solution communications, including the firewall rules checking, direct connecting from authentication/un authentication IP address testing, etc.

3 Description relates to 7.4.1.7.-2. (SP.05.03 BP)

(1) Provide a description can be performed for the Asset Owner to achieve the external communications to the Automation Solution, including remote access communications, shall not be able to interfere with the operation of the SIS.

(2) Document ID02 Table C.6 (through VCSC.31-02) could be used to review that the external communications to the Automation Solution, including remote access communications, shall not be able to interfere with the operation of the SIS.

(3) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In the figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to protect safety communications and SIS safety functions from the BPCS or any other Automation Solution communications. Also, it will be better that the firewall in Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(4) Section 9 presents the remote access management, including the multifactor authentication execution.

(5) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14 could be used to validate that the external communications to the Automation Solution, including remote access communications, shall not be able to interfere with the operation of the SIS, including the firewall rules checking, direct connecting from authentication/un authentication IP address testing, remote access management, etc.

4 Description relates to 7.4.1.7.-3. (SP.05.04 BP)

(1) Provide a description can be achieved for the Asset Owner to ensure the applications external to the SIS shall not be able to participate in disrupt or otherwise interfere with SIS communications that are critical to safety functions.

(2) Document ID02 Table C.6 (through VCSC.31-03) could be used to review that the applications external to the SIS shall not be able to participate in disrupt or otherwise interfere with SIS communications that are critical to safety functions.

(3) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In the figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to ensure that the applications external to the SIS shall not be able to participate in disrupt or otherwise interfere with SIS communications that are critical to safety functions. Also, it will be better that the firewall in Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(4) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14 could be used to validate that the applications external to the SIS shall not be able to participate in disrupt or otherwise interfere with SIS communications that are critical to safety functions, including the firewall rules checking, testing that the applications external to the SIS shall not be able to participate in disrupt or otherwise interfere with SIS communications, etc.

5 Description relates to 7.4.1.7.-4. (SP.05.05 BP)

(1) Provide a description can be achieved for the Asset Owner to ensure the SIS EWSs that reside outside the SIS should be protected from compromise by communications from Level 3 or above. Access from Level 3 applications to SIS engineering workstations that reside within the SIS is prohibited.

(2) Document ID02 Table C.6 (through VCSC.31-04) could be used to review that the SIS EWSs that reside outside the SIS should be protected from compromise by communications from Level 3 or above. Access from Level 3 applications to SIS engineering workstations that reside within the SIS is prohibited.

(3) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In the figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to ensure that access from Level 3 applications to SIS engineering workstations that reside within the SIS is prohibited. Also, it will be better that the firewall in Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(4) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14 could be used to validate that access from Level 3 applications to SIS engineering workstations that reside within the SIS is prohibited, including the firewall rules checking, testing that the access from Level 3 applications to SIS engineering workstations whether is prohibited, etc.

6 Description relates to 7.4.1.7.-5. (SP.05.05 RE (1))

(1) Provide a description can be achieved for the Asset Owner to ensure the SIS engineering workstations within the SIS (1a) either should not have remote access installed or (1b) should be disabled (not accessible), and/or (2) have security mechanisms that block remote access communications with these workstations.

(2) Document ID02 Table C.6 (through VCSC.31-05) could be used to review that the SIS engineering workstations within the SIS (1a) either should not have remote access installed or (1b) should be disabled (not accessible), and/or (2) have security mechanisms that block remote access communications with these workstations.

(3) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In the figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to ensure that the SIS engineering workstations within the SIS (1a) either

should not have remote access installed or (1b) should be disabled (not accessible), and/or (2) have security mechanisms that block remote access communications with these workstations. Also, it will be better that the firewall in Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(4) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14 could be used to validate that the SIS engineering workstations within the SIS (1a) either should not have remote access installed or (1b) should be disabled (not accessible), and/or (2) have security mechanisms that block remote access communications with these workstations, including remote access installed check, remote access disable configuration check, and security mechanisms used to block remote access communications check., etc.

7 Description relates to 7.4.1.7.-6. (SP.05.06 BP)

(1) Provide a description can be achieved for the Asset Owner to ensure all access to the Automation Solution's SIS from outside the SIS shall be mediated and authorized at the interface to the SIS. Access controls to the SIS should be implemented at the interface to the SIS.

(2) Document ID02 Table C.6 (through VCSC.31-06) could be used to review that all access to the Automation Solution's SIS from outside the SIS shall be mediated and authorized at the interface to the SIS. Access controls to the SIS should be implemented at the interface to the SIS.

(3) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In the figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to ensure that all access to the Automation Solution's SIS from outside the SIS shall be mediated and authorized at the interface to the SIS, where access controls to the SIS should be implemented at the interface to the SIS. Also, it will be better that the firewall in Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(4) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14 could be used to validate that all access to the Automation Solution's SIS from outside the SIS shall be mediated and authorized at the interface to the SIS, including firewall rules check to restrict access control from outside to SIS, whitelist available application and IP address with port check, and the implement of remote interactive access check refer to section, etc.

8 Description relates to 7.4.1.7.-7. (SP.05.07 BP)

(1) Provide a description can be achieved for the Asset Owner to ensure the SIS functions performed by the Automation Solution's SIS EWSs shall be protected from compromise by other SIS EWS software. It should reduce the possibility that the SIS EWS will contain T3 offline software (see IEC 61508-3) that could intentionally or inadvertently cause harm to the SIS.

(2) Document ID02 Table C.6 (through VCSC.31-07) could be used to review that the SIS functions performed by the Automation Solution's SIS EWSs shall be protected from compromise by other SIS EWS software.

(3) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In the figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to ensure that SIS functions shall be protected from compromise by other SIS EWS software. Also, it will be better that the firewall in Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(4) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14 could be used to validate that SIS functions performed by the Automation Solution's SIS EWSs shall be protected from compromise by other SIS EWS software, including check that whether the SIS EWS contains T3 offline software (see IEC 61508-3) to intentionally or inadvertently cause harm to the SIS, and test or inspect that safety-related software running in SIS EWSs is protected from compromise from other software running in the SIS EWS, etc.

9 Description relates to 7.4.1.7.-7. (SP.05.08 BP)

(1) Providing a description can be achieved for the Asset Owner to ensure that unauthorized wireless devices are not used as an integral part of SIS safety functions.

(2) Document ID02 Table C.6 (through VCSC.31-08) could be used to review that unauthorized wireless devices shall not be used as an integral part of SIS safety functions, to prevent attacks against the SIS by unauthorized wireless devices.

(3) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to ensure that unauthorized wireless devices shall not be used as an integral part of SIS safety functions. Also, it would be better if the firewall at Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(4) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14 could be used to validate that unauthorized wireless devices shall not be used as an integral part of SIS safety functions, to prevent attacks against the SIS by unauthorized wireless devices, including asset list of authorized wireless devices check, implementation of wireless security check when the PE/O allows authorized wireless devices could be used as an integral part of SIS safety

functions, and check that wireless device communications does not be used as an integral part of SIS safety functions when prohibited by the PE/O.

10 Description relates to 7.4.1.7.-8. (SP.05.09 BP)

(1) Provide a description can be achieved for the Asset Owner to enable and disable SIS configuration mode. While disabled, this interface shall prohibit the SIS from being configured.

(2) If implemented the SIS devices in the dummy project, it should ensure that the SIS devices provide the function to enable and disable SIS configuration mode with software or hardware implementation from user manual or similar documents.

(3) If implemented the SIS devices in the dummy project, it should provide a process document (e.g. has written procedures) to lock the SIS to prevent configuration changes from being made and unlock the SIS to allow configuration changes to be made. Locks could be physical key switches or software-controlled locks; however, when implemented, they allow the Project to follow its processes to lock the SIS to prevent inadvertent or malicious changes from being made.

(4) Document ID02 Table C.6 (through VCSC.31-09) could be used to review that the function to enable and disable SIS configuration mode shall be provided.

(5) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to ensure that unauthorized wireless devices shall not be used as an integral part of SIS safety functions. Also, it would be better if the firewall in Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(6) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14 could be used to validate that whether the function to enable and disable SIS configuration mode is provided in the implemented system of dummy project, including the firewall rules check that only authenticated (remote) access concontrol to configure the SIS devices, the SIS devices check whether provide the enable and disable SIS configuration mode, the SIS devices check whether prohibits the SIS from being configured while in disable mode.

11 Description relates to 7.4.1.7.-8. (1) (SP.05.09 RE (1)).

(1) Provide a function process and/or procedure document for the Asset Owner to to enable and disable a hardware implementation of the configuration mode interface required by SP.05.09 BR and to physically lock this hardware implementation while the configuration mode is disabled.

(2) If implemented the SIS devices in the dummy project, it should ensure that the SIS devices provide the function to enable and disable SIS configuration mode with software or hardware implementation from user manual or similar documents.

(3) If implemented the SIS devices in the dummy project, it should provide a process document (e.g. has written procedures) to lock the SIS to prevent configuration

changes from being made and unlock the SIS to allow configuration changes to be made. Locks could be physical key switches or software-controlled locks; however, when implemented, they allow the Project to follow its processes to lock the SIS to prevent inadvertent or malicious changes from being made.

(4) Document ID02 Table C.6 (through VCSC.31-09) could be used to review that the function to enable and disable SIS with a hardware implementation of the configuration mode interface shall be provided, review whether a function process and/or procedure document to enable and disable a hardware implementation of the configuration mode interface required by SP.05.09 BR and to physically lock this hardware implementation while the configuration mode is disabled.

(5) Document ID 08 is the Project/System Data Flow Diagram of dummy project and section 4 shows the updated SuC dataflow diagram after ILRA. In figure 2-3 of ID 08, Router with firewall in Purdue Level 2 should be configured the firewall rules to ensure that unauthorized wireless devices shall not be used as an integral part of SIS safety functions. Also, it would be better if the firewall in Purdue Level 3could be configured to restrict the connection to Router with firewall in Purdue Level 2.

(6) Also, Document ID 14 (OT Security Inspection and Test Protocol) section 3.14 could be used to validate that whether the function to enable and disable SIS configuration mode is provided in the implemented system of dummy project, including the firewall rules check that only authenticated (remote) access control to configure the SIS devices, the SIS devices check whether provide the enable and disable SIS configuration mode with hardware implementation, the SIS devices check whether are physically locked the hardware implementation while the configuration mode is disabled.

12 Description relates to 7.4.1.7.-8. (2) (SP.05.09 RE (2))

(1) Provide a function process and/or procedure document that can be performed for an independent third-party to verify that it is not possible to change the configuration of the SIS when the hardware interface described in SP.05.09 RE (1) is locked in the "disable" configuration mode.

(2) If implemented the SIS devices in the dummy project, it is suggested to verify that it is not possible to change the configuration of the SIS when the hardware interface is locked in the "disable" configuration mode by 3rd party where this 3rd party unit should be approved and documented by asset owner. The 3rd party should provide a report which is used to verify that the SIS configuration locking mechanism works.

13.0Wireless Security

13.1 Wireless Security (if applicable)

1 Description relates to 7.4.1.6.-1. (SP.04.01 BP)

Provide a description can be achieved for the Asset Owner to implement the following functions of the wireless systems:

(1) data exchange to/from wireless instrumentation: for example,

- Deploy wireless instrumentation compliant with industrial wireless communication standard, such as Wireless HART, or IEEE 802.15.4.
- Implement real-time monitoring to track data integrity and communication status.

(2) data exchange through a secure wireless link: for example,

- Utilize strong encryption protocols (e.g., AES-256, WPA3, TLS 1.2/1.3) to protect wireless communication.
- Configure VPN tunnels for secure remote access and inter-site data exchange.
- Use multi-factor authentication (MFA) for network access to enhance security.
- Regularly conduct penetration testing and wireless audits to identify and mitigate vulnerabilities.

(3) security mechanisms that prevent an intruder from gaining access to the Automation Solution using the wireless system: for example,

- Implement network segmentation to isolate the wireless network from critical control systems.
- Utilize role-based access control (RBAC) to limit unauthorized access.
- Deploy intrusion detection systems (IDS) with wireless anomaly detection capabilities.
- Enforce automatic session timeouts and re-authentication policies to prevent session hijacking.

(4) security mechanisms that restrict access within the Automation Solution by workers with handheld wireless devices: for example,

- Configure network access control to enforce security policies based on device type and user role.
- Use device certificates and endpoint security software to verify device authenticity.

(5) where required, security mechanisms that protect for remote management of wireless systems: for example,

- Enable secure remote management interfaces with encrypted communication (e.g., SSH, HTTPS).
- Use jump servers or secure remote access solutions (e.g., Bastion Hosts) to prevent direct internet exposure of wireless management interfaces.
- Restrict remote access to pre-approved IP addresses and enforce time-limited access policies.
- Implement audit logging and continuous monitoring of remote access

activities to detect and respond to anomalies.

2 Description relates to 7.4.1.6.-2. (SP.04.02 BP)

Provide a description can be achieved for the Asset Owner to provide the protection of wireless access shall be configured to use wireless authentication and access control mechanisms that are commonly accepted by both the security and industrial automation communities.

To protect wireless access within an industrial automation environment, the service provider should implement authentication and access control mechanisms that align with best practices from both security and industrial automation communities. This can be achieved through the following strategies:

(1) Implementing Strong Wireless Authentication Mechanisms: for example,
- Utilize 802.1X authentication with EAP-TLS (Extensible Authentication Protocol - Transport Layer Security) to ensure mutual authentication between devices and the network.
- Use RADIUS (Remote Authentication Dial-In User Service) or TACACS+ (Terminal Access Controller Access Control System Plus) for centralized authentication management.
- Deploy certificate-based authentication for wireless clients to eliminate reliance on weak credentials.
- Implement multi-factor authentication (MFA) for wireless access where applicable, especially for administrative users.

(2) Applying Role-Based Access Control (RBAC) & Network Segmentation: for example,
- Enforce RBAC policies to restrict access to wireless networks based on user roles, device types, and job responsibilities.
- Implement VLAN segmentation to separate wireless networks for operations, maintenance, and guest access.

(3) Configuring Secure Encryption Standards: for example,
- Ensure all wireless communications use encryption technology.
- Enable end-to-end encryption (E2EE) for data transmission between wireless devices and industrial control systems.

(4) Implementing Secure Wireless Access Control Mechanisms
- Use MAC address filtering combined with authentication to limit access to authorized devices.
- Configure wireless intrusion detection systems (WIDS) to monitor unauthorized access attempts and rogue access points.

(5) Monitoring & Maintaining Wireless Security Posture
- Conduct regular security audits and penetration testing to identify vulnerabilities in wireless access points.
- Implement real-time monitoring and logging of wireless activity using SIEM (Security Information and Event Management) tools.

3 Description relates to 7.4.1.6.-3. (SP.04.02 RE (1))

Provide a description can be achieved for the Asset Owner to provide the protection of wireless access shall be configured to protect wireless communications, and if cryptographic mechanisms are used for this purpose, they are commonly accepted by both the security and industrial automation communities

If cryptographic mechanisms are used to provide the protection of wireless access, they must adhere to recognized industry standards to ensure confidentiality, integrity, and authenticity of data transmissions. This can be achieved through the following strategies:

(1) Implementing Strong Encryption for Wireless Communications: for example
- Adopt WPA3-Enterprise or WPA2-Enterprise encryption to secure wireless access, ensuring protection against unauthorized interception.
- Utilize AES-256 encryption for all wireless data transmissions, as recommended by NIST (National Institute of Standards and Technology) and IEC 62443.
- Deploy end-to-end encryption (E2EE) to protect data exchanged between wireless devices and industrial control systems.
- Ensure VPN (Virtual Private Network) tunnelling with strong encryption algorithms (e.g., IPsec or TLS) for remote wireless access.

(2) Securing Cryptographic Key Management: for example,
- Implement a secure key lifecycle management system, including generation, distribution, storage, and rotation of encryption keys.
- Utilize PKI (Public Key Infrastructure) to establish trusted cryptographic identity verification between wireless clients and the network, if applicable.

4 Description relates to 7.4.1.6.-4. (SP.04.03 BR)

Provide a description can be achieved for the Asset Owner to ensure the wireless protocols used in the SuC should use commonly accepted standard wireless technology

This can be achieved through the following strategies:

(1) Adoption of Standardized Wireless Protocols: for example,
- Utilize only widely accepted and industry-proven wireless communication protocols such as IEEE 802.11ax, IEEE 802.11be, or IEEE 802.11ac.

(2) Ensure the wireless communication devices are certified by relevant industry bodies, such as Wi-Fi Alliance, ISA, IEEE, 3GPP, etc.

5 Description relates to 7.4.1.6.-5. (SP.04.03 RE (1))

Provide a description can be achieved for the Asset Owner to ensure the identifiers of the wireless network should not allow an external listener to identify the physical wireless network, its location, or the owner of the wireless network

To prevent external listeners from identifying the physical wireless network, its location, or the owner, the following strategies can be employed:

(1) Concealing Wireless Network Identifiers (SSID Cloaking): for example,

- Disable SSID broadcasting to prevent unauthorized devices from detecting the network name in public spaces.
- Use non-descriptive SSID names.

(2) Secure Authentication & Access Control: for example,

- Implement 802.1X authentication with a RADIUS server to restrict access to authorized devices only.
- Use MAC address filtering to limit device connections based on pre-approved lists (though not as a standalone security measure).

(3) Reduce Wireless Signal Leakage: for example,

- Adjust wireless access point (AP) power levels to limit the coverage area and reduce external detection.
- Use directional antennas instead of omnidirectional ones to focus the wireless signal within the facility.

(4) Implement Wireless Intrusion Detection Systems (WIDS)

- Deploy WIDS solutions to detect unauthorized scanning or rogue access points attempting to impersonate the network.
- Set up alerts for unauthorized SSID probing or suspicious connection attempts.

(5) Regularly Monitor & Audit Wireless Security

- Conduct periodic security assessments using network scanners to ensure no external visibility of network identifiers.
- Implement automated SSID security policies to enforce proper naming conventions and access control, if applicable.

6 Description relates to 7.4.1.6.-6. (SP.04.03 RE (2))

Provide a description can be achieved for the Asset Owner to ensure te wireless networks are configured to prevent:

(1) the use of unauthorized device addresses, and

(2) interference with the assignment of device addresses.

To ensure the wireless networks are configured to prevent, the following measures can be used to achieve these objectives:

Preventing the Use of Unauthorized Device Addresses

(1) Implement MAC Address Filtering:

- Configure MAC address filtering on wireless access points (APs) to allow only pre-approved devices to connect.
- Maintain a whitelist of authorized MAC addresses for all critical devices within the network.
- Regularly update and audit the approved MAC address list to prevent stale or compromised devices from gaining access.

(2) Use Secure Authentication Mechanisms

- Require 802.1X authentication with a RADIUS server to ensure only authorized users and devices can connect, if applicable.

(3) Deploy Wireless Intrusion Detection System (WIDS)

- Monitor for unauthorized MAC addresses attempting to connect to the network.
- Enable alerts for MAC address spoofing attempts, where an attacker mimics an authorized device's MAC address.

Preventing Interference with Device Address Assignments

(1) Secure Address Assignment Processes
- Use static IP assignments for critical devices to prevent unauthorized modifications.

(2) Encrypt Wireless Communications
- Use WPA3-Enterprise encryption to protect data, including address assignment processes, from eavesdropping, if applicable.

(3) Protect Against Rogue Access Points
- Configure wireless network policies to block unapproved access points.
- Regularly scan for unauthorized SSIDs and remove any that do not comply with security policies.

(4) Limit Broadcast Domain & Address Spoofing Risks
- Use VLAN segmentation to isolate different categories of devices, preventing address conflicts and unauthorized traffic routing.

Ongoing Monitoring & Compliance

(1) Conduct regular wireless security audits to verify that unauthorized device addresses are not present in the network.

(2) Use log monitoring and alerting tools to detect anomalies in device address assignments.

(3) Educate employees and contractors about security policies to prevent unauthorized devices from being introduced into the network.

<<Text End>>